

NETWORKING ESSENTIALS

Date: 09/10/2026

INTRODUCTION TO NETWORKING:

What Is Networking?

- Computer networking is the process of connecting two or more devices so they can communicate and share information. These devices can include computers, mobile phones, servers, printers, routers, and smart devices. For example, when you send a message, browse a website, or watch a video online, networking allows your device to communicate with another computer or server. A network uses physical or wireless connections and a set of communication rules called protocols

How Networking Works

- When you open a website, your device sends a request to a server. The request is divided into small units called packets. These packets travel through devices such as switches, routers, and internet service provider networks until they reach the destination server. The server processes the request and sends the required information back to your device. Your device then puts the packets together and displays the website.
- A simple example is sending a letter. Your device is the sender, the server is the receiver, the data is the message, the cable or Wi-Fi connection is the delivery path, and the protocol is the set of rules that explains how the message should be delivered.

Main Network Components

- A **device or node** is anything connected to a network, such as a computer, phone, printer, or server. A **network interface card**, also called a NIC, allows a device to connect to a wired or wireless network. Every network interface has a MAC address, which identifies the device on the local network.
- A **switch** connects multiple devices within the same local network. It receives data and forwards it to the correct device using MAC addresses. For example, computers in an office may all connect to the same switch so they can communicate and share resources.
- A **router** connects different networks and forwards data using IP addresses. Your home router connects your local home network to the internet. It decides where packets should go and selects an appropriate path for them.
- A **modem** connects your network to your internet service provider. It converts signals so that your router and the provider's network can communicate. A **wireless access point** provides Wi-Fi connectivity and allows wireless devices to join a network.

Types of Networks

- A **Personal Area Network**, or PAN, covers a very small area, such as the connection between a phone and wireless headphones. A **Local Area Network**, or LAN, connects devices in a limited area such as a home, classroom, office, or school.
- A **Metropolitan Area Network**, or MAN, covers a larger area such as a city or a group of buildings. A **Wide Area Network**, or WAN, connects networks across large geographic distances. The internet is the world's largest example of a WAN.

IP Addresses and MAC Addresses

- An IP address identifies a device on a network and helps routers deliver data to the correct destination. IPv4 addresses look like 192.168.1.10, while IPv6

uses a longer format to support many more devices. A device may receive its IP address automatically from a service called DHCP.

- A MAC address is a hardware identifier associated with a network interface. MAC addresses are mainly used for communication within a local network, while IP addresses are used to identify and route devices between different networks. In simple terms, a MAC address identifies a device locally, while an IP address helps locate it across networks.

Important Network Services

- DNS, or the Domain Name System, converts human-readable domain names into IP addresses. For example, when you type a website name into your browser, DNS helps find the server's IP address.
- DHCP, or Dynamic Host Configuration Protocol, automatically provides devices with network settings such as an IP address, subnet mask, default gateway, and DNS server. Without DHCP, users would often need to configure these settings manually.
- NAT, or Network Address Translation, allows multiple devices in a private network to share one public IP address when accessing the internet. This is commonly used by home and business routers.

Network Protocols

- A protocol is a set of rules that devices follow when communicating. **IP** is responsible for addressing and routing packets. **TCP** provides reliable communication by checking that data arrives correctly and in the proper order. **UDP** is faster than TCP but does not guarantee delivery, so it is commonly used for streaming, online gaming, and real-time communication.
- **HTTP and HTTPS** are used for websites. HTTPS protects web communication by encrypting the connection. **DNS** translates domain names into IP addresses. **SSH** allows secure remote access to systems, while **SMTP, IMAP, and POP3** are commonly used for sending and receiving email.

OSI Model:

The OSI model is a seven-layer framework used to understand how communication takes place across a network. Each layer performs a different function.

1. **Physical layer:** Transfers raw bits through cables, fiber, radio signals, or other physical media.
2. **Data Link layer:** Handles communication between devices on the same network and uses MAC addresses.
3. **Network layer:** Uses IP addresses to route packets between different networks.
4. **Transport layer:** Provides end-to-end communication. TCP and UDP work at this layer.
5. **Session layer:** Establishes, manages, and ends communication sessions.
6. **Presentation layer:** Handles data formatting, encryption, and compression.
7. **Application layer:** Provides network services used by applications, such as web browsing, email, and file sharing.

You can remember the OSI model as a way of dividing a complex networking process into smaller and easier-to-understand parts

Networking and Cybersecurity:

Networking is very important in cybersecurity because most attacks involve networks in some way. Security professionals need to understand IP addresses, ports, protocols, DNS, routing, firewalls, and network traffic.

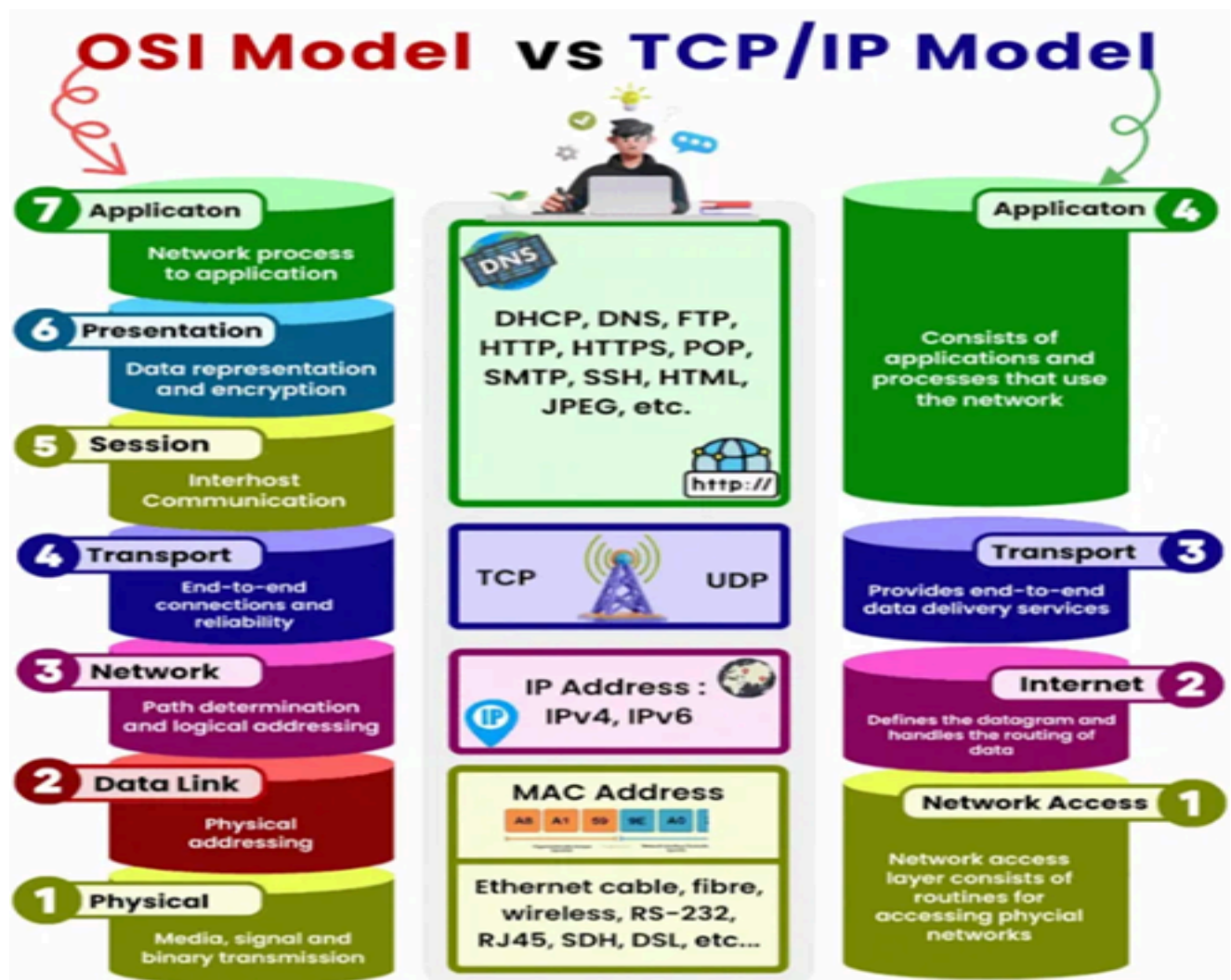
A **firewall** controls allowed and blocked network connections. **Network segmentation** divides a large network into smaller sections so that an attacker cannot easily move through the entire organization. An **IDS**, or Intrusion Detection System, detects suspicious activity, while an **IPS**, or Intrusion Prevention System, can actively block certain threats.

A SOC analyst also uses networking knowledge to investigate unusual connections, suspicious IP addresses, open ports, malware traffic, and unauthorized access.

Penetration testers use networking concepts to identify weaknesses, while blue teams use them to monitor and defend the network.

Simple Example

Suppose you type <https://example.com> into your browser. DNS first finds the website's IP address. Your device then sends packets through your Wi-Fi router and other routers across the internet. TCP or another transport protocol helps manage the communication, HTTPS encrypts the web traffic, and the destination server sends the website data back to your device. All of this happens within a few seconds through the combined work of network devices, IP addresses, protocols, and security controls.



TCP-IP MODEL:

What Is the TCP/IP Model?

The **TCP/IP model** is a networking framework that explains how devices communicate over the internet and other networks. TCP/IP stands for **Transmission Control Protocol/Internet Protocol**. It divides network communication into four layers, with each layer performing a specific function. These layers work together to deliver data from one device to another.

Four Layers of the TCP/IP Model

1. Application Layer

The Application layer is the top layer and is closest to the user. It provides network services that applications use to communicate. When you open a website, send an email, transfer a file, or connect remotely to a server, the Application layer is involved.

Common protocols at this layer include **HTTP and HTTPS** for websites, **DNS** for converting domain names into IP addresses, **FTP** for file transfers, **SMTP** for sending email, and **SSH** for secure remote access. For example, when you visit a website, your browser uses HTTPS at the Application layer to communicate with the web server.

2. Transport Layer

The Transport layer provides communication between applications running on different devices. It divides data into smaller pieces, controls the flow of information, and may ensure that the data arrives correctly and in the proper order.

The two main Transport layer protocols are **TCP** and **UDP**. TCP is connection-oriented and reliable because it checks delivery, maintains the correct order of data, and retransmits missing information. UDP is faster but does not guarantee delivery, so it is commonly used for live streaming, online gaming, voice calls, and video conferences. learn.

3. Internet Layer

The Internet layer is responsible for logical addressing and routing data between different networks. It places source and destination IP addresses into packets and helps routers decide where those packets should go.

The main protocol at this layer is **IP**, which includes IPv4 and IPv6. Other related protocols include **ICMP**, which is used for error messages and network testing, and **ARP**, which helps match an IP address with a MAC address on a local network. Routers mainly work with information from this layer to forward packets toward their destination.

4. Network Access Layer

The Network Access layer, also called the **Link layer** or **Network Interface layer**, handles the actual transmission of data across the local network. It includes the physical equipment and technologies used to send data through cables, fiber, or wireless signals.

Common examples include **Ethernet, Wi-Fi, PPP, fiber connections, and network cards**. This layer uses MAC addresses for local communication and creates frames that can travel across the network. Switches and network interface cards are closely related to this layer

Example: Opening a Website

When you type a website address into a browser, the TCP/IP layers work together. At the Application layer, the browser creates an HTTPS request. At the Transport layer, TCP breaks the request into segments and manages reliable delivery. At the Internet layer, IP adds source and destination addresses so routers know where to send the packets. Finally, at the Network Access layer, the packets are converted into frames and transmitted through Wi-Fi or an Ethernet cable.

When the web server receives the data, it processes the same layers in reverse order and sends the response back to your device.

TCP/IP Model and OSI Model

The TCP/IP model has four layers, while the OSI model has seven layers. The TCP/IP Application layer generally combines the OSI Application, Presentation, and Session layers. The TCP/IP Transport layer matches the OSI Transport layer. The TCP/IP Internet layer corresponds mainly to the OSI Network layer. The TCP/IP Network Access layer combines the OSI Data Link and Physical layers.[learn.microsoft+1](#)

TCP/IP layer	Related OSI layers	Main purpose
Application	Application, Presentation, Session	Provides services to applications
Transport	Transport	Provides end-to-end communication
Internet	Network	Handles IP addressing and routing
Network Access	Data Link, Physical	Sends data over the local network

TCP/IP and Cybersecurity

Understanding the TCP/IP model is important in cybersecurity because attacks can occur at every layer. Attackers may exploit web applications at the Application layer, scan ports at the Transport layer, spoof or attack IP addresses at the Internet layer, or target Wi-Fi and Ethernet networks at the Network Access layer.

Penetration testers use TCP/IP knowledge to scan ports, analyze traffic, test network services, and identify weaknesses. Blue teams and SOC analysts use it to investigate suspicious connections, unusual IP addresses, malicious DNS requests, and abnormal

network traffic. Firewalls, intrusion detection systems, VPNs, and network monitoring tools help protect different parts of the TCP/IP communication process.

IP address:

What Is an IP Address?

- An **IP address** is a numerical address assigned to a device on a network. It helps identify the device and allows data to be delivered to the correct destination. Just as a house needs a postal address to receive letters, a computer or phone needs an IP address to send and receive network data.
- For example, an IPv4 address may look like **192.168.1.10**. It identifies a device within a network and helps routers determine where packets should go.

IPv4 Addressing

- IPv4 is the most commonly taught version of IP addressing. An IPv4 address contains **32 bits** and is written as four decimal sections called octets. Each octet can have a value from 0 to 255. Example: **192.168.1.10** Each part represents 8 bits, making 32 bits in total. IPv4 provides approximately 4.3 billion possible addresses, but many addresses are reserved or unavailable for normal public use.

IPv6 Addressing

IPv6 was created because the number of available IPv4 addresses is limited. An IPv6 address contains **128 bits** and is written using hexadecimal numbers separated by colons .Example:**2001:db8:abcd::15** IPv6 provides a much larger address space than IPv4. It also supports features such as address auto-configuration and improved support for modern networks.

Network Portion and Host Portion

An IP address is divided into two main parts: the **network portion** and the **host portion**. The network portion identifies the network, while the host portion identifies a specific device on that network.

For example, with the address `192.168.1.10` and the subnet mask `255.255.255.0`, the first three sections identify the network:

Network portion: `192.168.1`

Host portion: `10`

This means the device belongs to the `192.168.1.0` network and has a host address of `10`.

Subnet Mask

A **subnet mask** tells a device which part of an IPv4 address represents the network and which part represents the host. A common subnet mask is:

`255.255.255.0`

This mask is also written in CIDR notation as `/24`. The `/24` means that the first 24 bits belong to the network portion, leaving 8 bits for hosts.

For example:

IP address: `192.168.1.10`

Subnet mask: `255.255.255.0`

CIDR: `192.168.1.10/24`

CIDR Notation

CIDR stands for **Classless Inter-Domain Routing**. It is a shorter and more flexible way to represent an IP address and its network prefix.

Examples include:

CIDR notation	Subnet mask	General meaning
/8	255.0.0.0	Large network
/16	255.255.0.0	Medium-sized network
/24	255.255.255.0	Common small network
/30	255.255.255.252	Very small network, often used for links

CIDR makes it possible to divide networks into smaller sections according to the organization's actual needs instead of using only old fixed address classes.

Network, Host, and Broadcast Addresses

A subnet usually contains three important types of addresses. The **network address** identifies the subnet itself. The **host addresses** are assigned to individual devices. The **broadcast address** is used to send data to all devices within the subnet.

For example, in the network 192.168.1.0/24:

Network address: 192.168.1.0

Usable host range: 192.168.1.1 – 192.168.1.254

Broadcast address: 192.168.1.255

In this example, 192.168.1.0 and 192.168.1.255 are normally reserved, leaving the addresses between them for devices.

Public and Private IP Addresses

A **private IP address** is used inside a local network, such as a home, office, or school network. Private addresses are not directly reachable from the public internet. Common private IPv4 ranges include:

- 10.0.0.0 – 10.255.255.255
- 172.16.0.0 – 172.31.255.255
- 192.168.0.0 – 192.168.255.255

A **public IP address** is assigned to a network or device that communicates directly over the internet. Your internet service provider usually assigns a public IP address to your home or business connection.

Static and Dynamic IP Addresses

A **static IP address** is manually assigned and normally remains unchanged. Static addresses are useful for servers, network devices, security cameras, and services that must always be reachable at the same address.

A **dynamic IP address** is assigned automatically, usually by DHCP. It may change over time. Most phones, laptops, and home devices use dynamic addressing because it is easier to manage.

DHCP

DHCP stands for **Dynamic Host Configuration Protocol**. It automatically provides a device with an IP address and other network settings, such as the subnet mask, default gateway, and DNS server.

When your laptop connects to Wi-Fi, the router usually gives it an address such as 192.168.1.25. Without DHCP, you would need to enter the network settings manually.

Default Gateway

The **default gateway** is usually the router that connects a local network to other networks or the internet. If a device wants to communicate with another device outside its local network, it sends the traffic to the default gateway.

For example, a laptop may have these settings:

IP address: 192.168.1.25

Subnet mask: 255.255.255.0

Default gateway: 192.168.1.1

DNS server: 8.8.8.8

Here, 192.168.1.1 is probably the local router.

DNS and IP Addresses

DNS, or the **Domain Name System**, converts easy-to-remember domain names into IP addresses. People prefer names such as `example.com`, but computers communicate using IP addresses.

For example:

`example.com` → an IP address

When you enter a website name into your browser, DNS finds the corresponding IP address so your device can contact the correct server.

NAT

NAT stands for **Network Address Translation**. It allows multiple devices in a private network to share one public IP address when connecting to the internet. A home router commonly performs NAT.

For example, phones, laptops, and smart TVs may use different private addresses inside the home, but all of them can access the internet through one public address provided by the internet service provider.

IP Addressing in Cybersecurity

IP addressing is very important in cybersecurity. Security professionals use IP addresses to identify suspicious systems, investigate network connections, create firewall rules, and monitor traffic. Penetration testers may scan IP addresses and ports to find exposed services, while SOC analysts investigate unusual communication with suspicious IP addresses.

However, an IP address alone does not always identify a specific person because addresses may be shared, dynamically assigned, hidden behind NAT, or changed over time. Therefore, security teams usually examine IP addresses together with logs, usernames, timestamps, device information, and other evidence.

TCP and UDP:

TCP and UDP are two important **Transport Layer protocols** used in computer networking. They help applications communicate between devices by sending data from one system to another. The main difference is that **TCP focuses on reliability and accuracy**, while **UDP focuses on speed and low overhead**.

TCP: Transmission Control Protocol

TCP is a **connection-oriented** protocol. Before sending data, it establishes a connection between the sender and receiver using a process called the **three-way handshake**. After the connection is created, TCP makes sure that data reaches the destination correctly, in the correct order, and without duplication.

TCP uses acknowledgments to confirm that data was received. If a packet is lost or damaged, TCP retransmits it. It also uses flow control to prevent the receiver from becoming overloaded and congestion control to reduce traffic problems on the network. Because of these features, TCP is reliable but usually has more overhead and may be slower than UDP.¹

TCP is commonly used when every piece of data must arrive correctly. Examples include:

- Websites using HTTP or HTTPS.
- File transfers using FTP or SFTP.
- Email communication.
- Remote access using SSH.
- Database connections.

For example, when downloading a file, missing even a small part can make the file unusable. TCP ensures that the complete file arrives correctly.

UDP: User Datagram Protocol

UDP is a **connectionless** protocol. It does not establish a formal connection before sending data and does not wait for acknowledgments. It also does not guarantee that packets will arrive, arrive in the correct order, or arrive only once.

Because UDP has fewer control mechanisms, it is faster and creates less network overhead than TCP. Applications choose UDP when speed and low delay are more important than perfect delivery. If a small amount of data is lost during a live video or online game, the application may continue working without waiting for retransmission.

UDP is commonly used for:

- Live video and audio streaming.
- Online gaming.
- Voice and video calls.
- DNS queries.
- DHCP.
- Real-time monitoring and telemetry.

For example, during a video call, receiving the latest audio quickly is usually more important than retransmitting a previous sentence several seconds later.

TCP vs. UDP

Feature

TCP

UDP

Connection	Connection-oriented	Connectionless
Handshake	Uses a three-way handshake	No handshake
Reliability	Reliable delivery	Best-effort delivery
Packet order	Maintains the correct order	Does not guarantee order
Lost packets	Retransmits lost data	Normally does not retransmit
Acknowledgments	Uses acknowledgments	Does not use standard acknowledgments
Speed	Generally slower	Generally faster
Overhead	Higher	Lower
Flow control	Supported	Not provided by UDP itself
Congestion control	Supported	Not provided by UDP itself
Data type	Reliable byte stream	Individual datagrams

TCP Three-Way Handshake

TCP normally begins communication using three steps:

1. The client sends a **SYN** message to request a connection.
2. The server replies with **SYN-ACK** to accept the request.
3. The client sends an **ACK** to confirm the connection.

After these steps, the two devices can begin exchanging data. When the communication ends, TCP uses additional messages to close the connection properly.

TCP and UDP Ports

Both TCP and UDP use **port numbers** to identify specific applications or services on a device. An IP address identifies the device, while a port identifies the application or service.

For example:

- TCP port 443 is commonly used for HTTPS.
- TCP port 22 is commonly used for SSH.
- UDP port 53 is commonly used for DNS.
- UDP port 67 and 68 are commonly used for DHCP.

The same port number can sometimes be used separately by TCP and UDP because they are different transport protocols.

TCP and UDP in Cybersecurity

Cybersecurity professionals need to understand TCP and UDP when analyzing network traffic. A SOC analyst may investigate unusual TCP connections, repeated connection attempts, open ports, or suspicious UDP traffic. Penetration testers may scan TCP and UDP ports to find exposed services.

Attackers may perform TCP SYN scans, UDP scans, denial-of-service attacks, or exploit vulnerable services. Firewalls and intrusion detection systems often use IP addresses, protocols, and port numbers to allow or block traffic. Understanding whether a service uses TCP or UDP helps security teams create accurate firewall rules and investigate alerts.

Simple Example

Imagine sending a package and a text message. **TCP** is like a registered package delivery service: it confirms the destination, tracks the package, checks whether it

arrived, and sends it again if it is lost. **UDP** is like quickly shouting a message across a room: it is fast and simple, but there is no guarantee that the message will be heard correctly.

What Are Ports and Protocols?

A **protocol** is a set of rules that defines how devices communicate over a network. A **port** is a logical number used to identify a specific service or application running on a device.

An IP address identifies the device, while a port identifies the service on that device. For example, an IP address may identify a web server, and port **443** identifies its HTTPS service.

You can think of an IP address as a building address and a port as a particular room inside that building. This combination allows network traffic to reach the correct application.

What Is a Port?

Port numbers range from **0** to **65535**. They work with transport protocols such as TCP and UDP. IANA, the Internet Assigned Numbers Authority, maintains the official service and port registry

Ports are divided into three main ranges:

Port range	Name	Purpose
0–1023	Well-known or system ports	Common standard services
1024–49151	Registered ports	Applications and vendor services

49152–65 Dynamic or private ports Temporary client connections
535

When your computer connects to a web server, it usually uses a temporary source port, while the server listens on a well-known destination port such as 80 or 443.

What Is a Protocol?

A protocol explains how data should be formatted, transmitted, received, and interpreted. Protocols can operate at different layers of the TCP/IP model.

For example:

- **HTTP** defines how web browsers and web servers communicate.
- **DNS** defines how domain names are converted into IP addresses.
- **TCP** provides reliable transport.
- **UDP** provides faster, connectionless transport.
- **SSH** defines secure remote access.
- **SMTP** defines how email is sent.

A service normally uses a protocol together with a port. For example, HTTPS commonly uses TCP port 443.

Common Ports and Protocols

Port	Protocol or service	Transport	Purpose
20	FTP data	TCP	Transfers FTP data
21	FTP control	TCP	Controls FTP sessions

22	SSH	TCP	Secure remote login and administration
23	Telnet	TCP	Remote access without encryption; generally unsafe
25	SMTP	TCP	Email transfer between mail servers
53	DNS	TCP/UDP	Resolves domain names to IP addresses
67/ 68	DHCP	UDP	Assigns IP configuration automatically
80	HTTP	TCP	Unencrypted web traffic
110	POP3	TCP	Receiving email
123	NTP	UDP	Synchronizing time
143	IMAP	TCP	Accessing email
161	SNMP	UDP	Monitoring and managing network devices
389	LDAP	TCP/UDP	Directory services
443	HTTPS	TCP, or UDP with HTTP/3	Encrypted web traffic
445	SMB	TCP	File and printer sharing
636	LDAPS	TCP	Secure LDAP

993	IMAPS	TCP	Secure IMAP email
-----	-------	-----	-------------------

995	POP3S	TCP	Secure POP3 email
-----	-------	-----	-------------------

Port assignments can vary by implementation, so the official IANA registry should be checked when exact service information is required

TCP Ports and UDP Ports

TCP and UDP use separate port spaces. A service using TCP port 53 is technically different from a service using UDP port 53, even though the number is the same.

TCP provides reliable communication. It establishes a connection, confirms delivery, preserves packet order, and retransmits missing data. Websites, SSH, email, and file transfers commonly use TCP.

UDP does not establish a formal connection and does not guarantee delivery or packet order. It is faster and has less overhead, making it useful for DNS queries, streaming, online gaming, voice calls, and DHCP.

Source and Destination Ports

When a client connects to a server, the communication normally includes four important values

Source IP address

Source port

Destination IP address

Destination port

For example:

Source IP: 192.168.1.25

Source port: 51842

Destination IP: 93.184.216.34

Destination port: 443

Protocol: TCP

Here, the client uses temporary source port 51842 to connect to the server's HTTPS service on port 443.

Client Ports and Server Ports

A **server** listens on a known port for incoming connections. For example, an HTTPS server listens on port 443.

A **client** usually receives a temporary dynamic port when it starts a connection. The operating system chooses this port automatically. The client uses it so that the response can be delivered to the correct application.

This is why one computer can browse several websites at the same time. Each connection can use a different temporary source port.

Open, Closed, and Filtered Ports

An **open port** means that a service is listening and accepting connections. An **open port is not automatically a vulnerability**, but it increases the attack surface and should be properly secured.

A **closed port** means that no service is currently accepting connections, although the device may respond to the connection attempt.

A **filtered port** usually means that a firewall or security device is blocking the request or preventing the scanner from determining whether a service is available.

Ports in Cybersecurity

Ports are important in penetration testing, network defense, and SOC investigations. A penetration tester may scan authorized systems to identify exposed ports and

determine which services are running. A blue team may close unnecessary ports, restrict access with firewall rules, and monitor unusual connections.

For example, an internet-facing server may need port 443 open for HTTPS, but administrative SSH access on port 22 should usually be restricted to trusted administrator networks. Exposing unnecessary services can give attackers additional opportunities.

Security teams also investigate suspicious activity such as repeated connection attempts, unusual outbound ports, unexpected services, or connections to known malicious addresses. Tools such as nmap, firewall logs, SIEM platforms, and network-monitoring systems are commonly used for this purpose.

Simple Example

When you visit a secure website, your browser may create a connection like this:

Your device: 192.168.1.20:52000

Web server: 203.0.113.10:443

Protocol: TCP

Your device uses a temporary source port, 52000, while the web server listens on port 443 for HTTPS traffic. The IP addresses identify the devices, TCP manages the connection, and HTTPS protects the web data.

DNS, DHCP, ARP and Other Important Protocols

DNS, DHCP, and ARP are important networking protocols that help devices communicate. DHCP gives a device its network settings, DNS converts website names into IP addresses, and ARP connects an IPv4 address to a MAC address on the local network. Together, they help a device join a network, find destinations, and deliver data correctly.

DNS

DNS stands for **Domain Name System**. It translates human-readable domain names into IP addresses. People can easily remember names such as `google.com`, but computers use IP addresses to communicate.

For example:

`www.example.com` → `203.0.113.10`

When you type a website name into your browser, your device sends a DNS query to a DNS server. The DNS server finds the correct IP address and returns it to your device. Your browser then uses that IP address to connect to the web server.

DNS commonly uses **UDP port 53** for normal queries. It can also use **TCP port 53**, especially for larger responses or certain DNS operations.

Important DNS record types include:

- **A record:** Maps a domain name to an IPv4 address.
- **AAAA record:** Maps a domain name to an IPv6 address.
- **CNAME record:** Creates an alias for another domain name.
- **MX record:** Identifies mail servers for a domain.
- **NS record:** Identifies authoritative name servers.
- **TXT record:** Stores text information, often used for verification and email security.

DNS normally works through several levels. A recursive DNS resolver receives a query from the user's device. If the answer is not already cached, it may contact root servers, top-level domain servers, and the authoritative server for the requested domain.

From a cybersecurity perspective, DNS is important because attackers may use malicious domains for phishing, command-and-control communication, malware delivery, or data exfiltration. Security teams monitor unusual DNS requests, newly registered domains, and connections to known malicious domains.

DHCP

DHCP stands for **Dynamic Host Configuration Protocol**. It automatically provides devices with the network settings they need to communicate. These settings may include an IP address, subnet mask, default gateway, DNS server, and lease duration

Without DHCP, every device would need to be configured manually. When your laptop connects to Wi-Fi, the router or DHCP server usually provides an address such as:

IP address: 192.168.1.25
Subnet mask: 255.255.255.0
Default gateway: 192.168.1.1
DNS server: 192.168.1.1

DHCP commonly uses **UDP port 67** on the server side and **UDP port 68** on the client side.

The basic DHCP process is often remembered as **DORA**:

1. **Discover:** The client broadcasts a request looking for a DHCP server.
2. **Offer:** A DHCP server offers an IP address and network settings.
3. **Request:** The client requests the offered address.
4. **Acknowledgment:** The server confirms the assignment.

The address is usually leased for a specific period. When the lease is close to expiring, the device can renew it.

In cybersecurity, attackers may create a fake DHCP server to provide incorrect gateways or DNS servers. This can redirect users to malicious websites or allow traffic interception. Network teams can reduce this risk by using DHCP snooping and trusted switch ports.

ARP

ARP stands for **Address Resolution Protocol**. It is used in IPv4 networks to discover the MAC address associated with a known IP address. IP addresses operate at the Network layer, while MAC addresses are used for local network delivery.

Suppose a computer wants to send data to `192.168.1.15`, but it does not know the device's MAC address. It sends an ARP request to the local network asking:

`Who has 192.168.1.15?`

The device using that IP address replies with its MAC address:

`192.168.1.15 is at AA:BB:CC:11:22:33`

The sending computer stores this information in its **ARP cache** for a period of time. It can then place the destination MAC address into the Ethernet frame and send the data.

ARP works only within the local network. If the destination is outside the local subnet, the computer usually resolves the MAC address of the default gateway instead of the remote server.

A major security issue is **ARP spoofing or ARP poisoning**. In this attack, an attacker sends false ARP messages and claims to be another device, often the gateway. This can allow traffic interception through a man-in-the-middle attack. Security teams can use static ARP entries, network monitoring, dynamic ARP inspection, and encryption such as HTTPS to reduce the risk.

ICMP

ICMP stands for **Internet Control Message Protocol**. It is used for network error messages, diagnostics, and control information. The `ping` command commonly uses ICMP Echo Request and Echo Reply messages to test whether a device is reachable.

The `tracert` or `tracert` command also uses ICMP or related packet behavior to show the path traffic takes through routers.

ICMP is useful for troubleshooting, but attackers may use it for scanning, reconnaissance, or denial-of-service attacks. Firewalls often restrict some ICMP traffic while allowing messages needed for normal network operation.

HTTP and HTTPS

HTTP stands for **Hypertext Transfer Protocol** and is used for communication between web browsers and web servers. HTTP commonly uses TCP port 80.

HTTPS is HTTP protected by TLS encryption. It commonly uses TCP port 443, although HTTP/3 can use UDP through QUIC. HTTPS protects data from being easily read or modified while it travels between the browser and server.

HTTPS helps protect passwords, payment information, session cookies, and other web data. However, HTTPS does not automatically mean that a website is trustworthy; a malicious website can also use HTTPS.

FTP, SFTP, and TFTP

FTP stands for **File Transfer Protocol**. It is used to transfer files but does not provide strong encryption by itself. FTP commonly uses TCP ports 20 and 21.

SFTP stands for **SSH File Transfer Protocol**. It transfers files securely through SSH and commonly uses TCP port 22.

TFTP stands for **Trivial File Transfer Protocol**. It is a simple file-transfer protocol that uses UDP and is often used for network device boot files or configuration transfers. Because it has limited security features, it should be used carefully in controlled environments.

SSH and Telnet

SSH stands for **Secure Shell** and is used for encrypted remote access and administration. It commonly uses TCP port 22. Network administrators use SSH to manage servers, routers, switches, and other devices securely.

Telnet also provides remote command-line access, but it sends information, including credentials, without encryption. It commonly uses TCP port 23 and is generally avoided in favor of SSH.

SMTP, POP3, and IMAP

These protocols support email communication. **SMTP** is used to send email and commonly uses TCP port 25, 587, or 465, depending on the configuration.

POP3 downloads email from a mail server and commonly uses TCP port 110. Secure POP3, called POP3S, commonly uses port 995.

IMAP allows users to access and synchronize email while keeping messages on the server. It commonly uses TCP port 143. Secure IMAP commonly uses port 993.

NTP

NTP stands for **Network Time Protocol**. It synchronizes the clocks of computers and network devices. NTP commonly uses UDP port 123.

Accurate time is important for cybersecurity because logs from different systems must have matching timestamps. If system clocks are incorrect, it becomes more difficult to investigate incidents and reconstruct an attack.

SNMP

SNMP stands for **Simple Network Management Protocol**. It allows administrators to monitor and manage network devices such as routers, switches, printers, and servers.

SNMP commonly uses UDP port 161 for queries and UDP port 162 for traps or alerts. Older versions of SNMP may transmit community strings without strong protection, so secure configurations and SNMPv3 are preferred.

NAT

NAT stands for **Network Address Translation**. It allows multiple private devices to share one public IP address when accessing the internet. A home router commonly performs NAT.

For example, several devices may use addresses such as 192.168.1.10, 192.168.1.11, and 192.168.1.12 internally, while they all use one public address when communicating with internet servers.

NAT is not a complete security solution, but it can prevent unsolicited inbound connections unless port forwarding or another rule allows them.

How These Protocols Work Together

When a laptop connects to a Wi-Fi network and opens a website, several protocols may work together:

1. **DHCP** gives the laptop an IP address, subnet mask, gateway, and DNS server.
2. **DNS** converts the website name into an IP address.
3. The laptop determines whether the destination is local or remote.
4. **ARP** finds the MAC address of the local gateway if the destination is outside the local network.
5. **TCP or UDP** transports the application data.
6. **HTTPS** protects web traffic when the website uses encryption.
7. **NAT** may translate the private IP address into the router's public IP address.
8. **ICMP, NTP, and other protocols** may support diagnostics, timing, and network management.

This shows that networking is not based on one protocol. Multiple protocols cooperate at different layers to provide connectivity, addressing, name resolution, data delivery, security, and troubleshooting.

Routing and Switching:

Routing and switching are two basic networking functions that allow devices to communicate. **Switching** connects devices within the same local network, while **routing** connects different networks and decides where IP packets should go. Together, they form the foundation of home, office, data-center, and internet networks.

Switching

Switching is the process of forwarding data between devices on the same local network. A **switch** usually works at Layer 2 of the OSI model and uses MAC addresses to decide where to send Ethernet frames.

For example, if several computers are connected to the same office switch, the switch learns the MAC address of each device. When one computer sends data to another, the switch forwards the frame only to the correct port instead of sending it to every connected device.

A switch learns MAC addresses by observing the source MAC address of incoming frames and storing it in a MAC address table. If the destination MAC address is known, the switch sends the frame to the appropriate port. If it is unknown, the switch may temporarily flood the frame to other ports in the same VLAN.

Router

A router connects different networks. Unlike a basic Layer 2 switch, a router makes forwarding decisions using IP addresses. It examines the destination IP address in a packet and checks its routing table to determine the next destination.

For example, a home router may connect:

Home network: 192.168.1.0/24

Internet connection: Public IP network

When a device in the home network accesses a website, the router forwards the traffic from the private home network toward the internet.

A router can connect different LANs, WANs, VLANs, branch offices, cloud networks, and internet service providers.

Routing Table

A **routing table** is a list of networks and the paths used to reach them. A router checks this table when it receives a packet.

A routing table may contain:

- The destination network.
- The subnet mask or prefix length.
- The next-hop router.
- The outgoing interface.
- The route source or routing protocol.
- A metric used to choose between routes.

For example:

Destination network: 10.10.20.0/24

Next hop: 192.168.1.1

Outgoing interface: GigabitEthernet0/1

If multiple routes are available, the router generally selects the most specific matching route. If routes have the same level of specificity, administrative distance and metric may influence the decision.

Default Gateway

A **default gateway** is the router a device uses when the destination is outside its local network. If a computer wants to communicate with another device on the same subnet, it sends the traffic directly to that device. If the destination is on another network, it sends the traffic to the default gateway.

For example:

Computer IP: 192.168.1.25

Subnet mask: 255.255.255.0

Default gateway: 192.168.1.1

The computer sends internet traffic to 192.168.1.1, which then routes it toward the destination.

Static Routing

A **static route** is manually configured by a network administrator. It does not automatically change if the network topology changes.

Static routing is useful for:

- Small and simple networks.
- Default routes.
- Backup paths.
- Specific security or traffic-control requirements.
- Networks where predictable routing is important.

However, manually configuring many routes can become difficult in a large network.

Dynamic Routing

Dynamic routing uses routing protocols to exchange information between routers. Routers automatically learn available networks and can update their routes when the network changes.

Common dynamic routing protocols include:

- **OSPF:** Common inside organizations and enterprise networks.
- **EIGRP:** A Cisco routing protocol used in some environments.
- **BGP:** Used to exchange routes between large networks and internet service providers.
- **RIP:** An older and simpler routing protocol with limited scalability.

Dynamic routing is useful when a network has many routers or multiple possible paths.

VLANs

A VLAN, or **Virtual Local Area Network**, divides one physical switch into multiple logical networks. Devices in different VLANs are separated even if they are connected to the same physical switch.

For example:

VLAN 10: Employees

VLAN 20: Finance

VLAN 30: Guests

VLANs improve organization, performance, and security. Guest devices can be isolated from internal systems, while finance devices can be placed in a more restricted network.

Devices in the same VLAN can communicate through Layer 2 switching. Devices in different VLANs require routing.

Access Ports and Trunk Ports

An **access port** carries traffic for one VLAN and is commonly used to connect end devices such as computers, printers, or phones.

A **trunk port** carries traffic for multiple VLANs between switches, routers, or Layer 3 switches. Trunk links commonly use IEEE 802.1Q VLAN tagging to identify which VLAN each frame belongs to.

For example, if VLANs 10, 20, and 30 exist on two switches, a trunk link can carry traffic for all three VLANs between the switches.

Inter-VLAN Routing

Inter-VLAN routing allows devices in different VLANs to communicate. Because VLANs are separate Layer 2 networks, a router or Layer 3 switch is needed to move traffic between them.cisco+1

There are several ways to perform inter-VLAN routing:

- **Router-on-a-stick:** One router interface uses multiple subinterfaces, with each subinterface representing a VLAN.
- **Layer 3 switch with SVIs:** A switch creates a switched virtual interface for each VLAN and routes traffic internally.
- **Separate router interfaces:** A router uses a different physical interface for each VLAN.

Layer 3 switches commonly use **SVIs**, or switched virtual interfaces, to route between VLANs.

Layer 2 and Layer 3 Switching

A **Layer 2 switch** forwards Ethernet frames using MAC addresses. It mainly operates within a VLAN and does not normally route traffic between different IP networks.

A **Layer 3 switch** can perform both switching and routing. It forwards local traffic using MAC addresses and routes traffic between VLANs or IP networks using IP addresses.

Layer 3 switching is common in campus and enterprise networks because it can provide fast communication between VLANs without sending all traffic to a separate router.

Network Address Translation

NAT, or **Network Address Translation**, changes private IP addresses into public IP addresses. It allows multiple internal devices to share one public internet address.

For example:

Private device: 192.168.1.25:52000

Public address: 203.0.113.50:52000

The router records the translation so that returning traffic can be sent back to the correct internal device. NAT is common in home networks and business networks.

Routing and Switching in Cybersecurity

Routing and switching knowledge is essential for cybersecurity because security controls depend on network design. Firewalls, VLANs, access control lists, intrusion detection systems, and network monitoring all require an understanding of how traffic moves.

Network segmentation can limit an attacker's movement. For example, user computers, servers, administrative systems, and guest devices can be placed in separate VLANs

with firewall rules between them. If an attacker compromises a guest laptop, proper segmentation can prevent direct access to sensitive database servers.

SOC analysts also examine routing and switching information when investigating suspicious traffic. They may review VLANs, switch logs, routing tables, firewall logs, MAC address tables, and ARP activity.

Important Network Devices

A **hub** sends incoming data to every connected port and does not make intelligent forwarding decisions. Hubs are largely obsolete.

A **switch** connects devices within a local network and forwards frames using MAC addresses.

A **router** connects different networks and forwards packets using IP addresses.

A **firewall** allows or blocks traffic based on rules such as IP addresses, ports, protocols, applications, and user identities.

A **wireless access point** connects wireless devices to a wired network.

A **Layer 3 switch** performs both switching and routing functions.

Simple Example

Imagine a company with three departments:

VLAN 10: Employees

VLAN 20: Finance

VLAN 30: Guests

A switch forwards traffic between devices inside the same VLAN. A Layer 3 switch or router handles communication between the VLANs. Firewall rules may allow employees to access internal applications, restrict finance systems to authorized users, and completely block guests from sensitive company servers. This combination of

switching, routing, VLANs, and security controls creates an organized and protected network.

What Is Network Topology?

A **network topology** is the structure or arrangement of a network. It explains how computers, switches, routers, servers, wireless access points, firewalls, and other devices are connected and how data travels between them.

Topology has two meanings:

- **Physical topology:** The actual arrangement of cables, devices, racks, and connections.
- **Logical topology:** The way data moves through the network, regardless of the physical cabling.

For example, a company may physically connect all computers to the same switch, but logically separate them into employee, finance, guest, and server networks using VLANs and firewall rules.

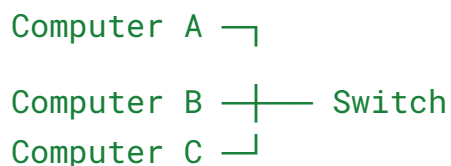
Topology is important in cybersecurity because it determines:

- Which systems can communicate.
- Where security controls can be placed.
- How easily an attacker can move.
- Where traffic can be monitored.
- Whether one device failure can stop the network.
- Which systems become critical points of attack.

A network with unrestricted communication creates many attack paths. A well-designed network limits communication, separates sensitive systems, and places monitoring at important traffic points

Star Topology

In a **star topology**, each device connects to a central device, usually a switch or wireless access point. The connected computers do not normally connect directly to one another; their traffic passes through the central device.



When Computer A communicates with Computer B, the traffic first reaches the switch. The switch examines the destination MAC address and forwards the frame to the correct port.

Advantages

Star topology is popular because it is easy to install, manage, troubleshoot, and expand. If one cable fails, usually only the connected device loses connectivity. It also makes it easier to monitor traffic because the switch is a central point through which local communication passes.

Disadvantages

The central switch becomes an important dependency. If the switch fails, many or all connected devices may lose network access. If the switch is poorly configured or compromised, an attacker may affect multiple devices.

A star topology can also create a central target for denial-of-service attacks or administrative compromise. Organizations reduce this risk with redundant switches, backup links, secure management, access controls, firmware updates, and monitoring.

Security Example

Suppose all employees connect to one switch and the switch places everyone in one flat network. If an attacker compromises one employee laptop, they may scan and attack other devices on that network.

A more secure design uses the same physical star shape but creates separate logical networks:

VLAN 10: Employees

VLAN 20: Finance

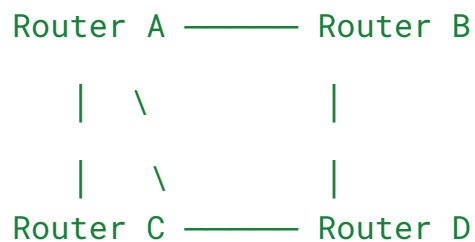
VLAN 30: Servers

VLAN 40: Guests

Traffic between these VLANs passes through routing and firewall controls instead of being freely switched.

Mesh Topology

In a **mesh topology**, devices have multiple connections to one another. A full mesh connects every device to every other device, while a partial mesh provides multiple connections only where redundancy is important.



If one link fails, traffic may use another path. This makes mesh topology highly resilient and useful for service providers, data centers, wireless systems, and critical infrastructure.

Advantages

The biggest benefit is **redundancy**. A single cable, router, or link failure may not interrupt communication because another path is available. Mesh networks can also support load sharing and faster recovery.

Disadvantages

Mesh topology is more expensive and difficult to manage. More links mean more configurations, routing decisions, firewall policies, certificates, monitoring requirements, and possible misconfigurations.

From a security perspective, every additional connection can create another path that must be protected. More paths may improve availability but also increase the number of routes an attacker could use for lateral movement

Security Example

Imagine that a database network has direct connections to an application network, backup network, administrator network, and monitoring network. If firewall policies are not consistent across all of these paths, an attacker may bypass one protected route by using another less-protected route.

For this reason, mesh designs require centralized policy management, strong authentication, routing controls, access lists, segmentation, and continuous monitoring.

Ring Topology

In a **ring topology**, each device connects to two neighboring devices, creating a circular path.

Device A — Device B

Device D — Device C

Data travels around the ring, either in one direction or, in some designs, in both directions. Older network technologies used token-based communication, where devices transmitted when they received permission or a token.

Advantages

A ring can provide predictable traffic flow and may avoid some collisions found in older shared networks. A dual-ring design can provide an alternative path if one section fails.

Disadvantages

A failure in one device or link can disrupt communication in a single-ring design. Troubleshooting can also be more complicated because a problem at one point may affect devices farther around the ring.

From a security perspective, a compromised device may observe or interfere with traffic passing through it. Modern technologies often use redundancy and encryption to reduce this risk.

Practical Use

Pure ring topologies are less common in ordinary office LANs today, but ring-like designs may still appear in metropolitan networks, industrial systems, telecommunications, and resilient provider networks.

Bus Topology

In a **bus topology**, all devices share one main communication cable or backbone.

Device A — Device B — Device C — Device D
Shared backbone

When a device transmits, the signal travels across the shared medium. Each device checks whether the data is intended for it.

Advantages

Bus topology was once attractive because it required less cabling and was relatively simple to install. It could work for small, temporary, or older networks.

Disadvantages

The shared backbone creates a major single point of failure. If the main cable is damaged, the entire network may be affected. Performance also decreases as more devices share the same communication medium.

Bus networks provide weak isolation. A device connected to the shared cable may be able to observe traffic intended for others, especially if encryption and switching protections are not present. Modern Ethernet networks generally use switches rather than a shared bus because switches provide better performance and isolation.

Cybersecurity Risk

A bus-like or flat network makes packet sniffing, unauthorized monitoring, and lateral movement easier. It also makes it difficult to place precise access controls between devices.

Hub-and-Spoke Topology

A **hub-and-spoke topology** connects multiple branch networks or remote locations to a central hub.



This is common when branch offices connect to a central data center, headquarters, or cloud security service.

Advantages

The central hub makes management, policy enforcement, logging, and monitoring easier. Security tools such as firewalls, VPN concentrators, and IDS/IPS systems can be placed at the hub.

Disadvantages

The central hub can become a bottleneck and a single point of failure. If the hub or its internet connection fails, multiple branches may lose access to shared resources.

The hub is also an attractive target for attackers. A compromise of the central firewall, VPN gateway, or identity service could affect many branches at once.

Security Example

A company may require all branch traffic to pass through headquarters for inspection. This improves centralized visibility but can increase latency and create a dependency on the central site. Redundant hubs, backup VPNs, and local failover controls can improve resilience.

Hybrid Topology

A **hybrid topology** combines two or more topology types. For example, each office may use a star topology internally, while offices connect to headquarters in a hub-and-spoke or partial-mesh design.

Office LAN A: Star

Office LAN B: Star

Office LAN C: Star

All offices: Connected through a WAN mesh or hub

Most modern enterprise networks are hybrid. They may contain:

- Star-connected users.
- Mesh-connected data centers.
- Hub-and-spoke branch networks.
- Ring-based provider links.
- Segmented cloud networks.
- Wireless and wired sections.

Advantages

Hybrid designs can be optimized for cost, performance, availability, and security. Critical systems can receive redundant connections, while ordinary user devices can use a simpler design.

Disadvantages

Hybrid networks are more difficult to document and manage. Different technologies may use different security policies, routing protocols, authentication methods, and monitoring tools.

An incomplete network diagram is itself a security risk. If defenders do not know that a backup link, cloud connection, wireless bridge, or remote-access path exists, attackers may use it without being detected.

Tree or Hierarchical Topology

A **tree topology** organizes devices into layers, usually called access, distribution, and core layers.

Core layer

|

Distribution layer

├─ Access switch

├─ Access switch

└─ Access switch

The access layer connects users and endpoints. The distribution layer applies routing, policy, and aggregation. The core layer provides fast connectivity between major network sections.

Advantages

Hierarchical design makes large networks easier to organize and scale. Policies can be applied at suitable layers, and traffic flows are easier to understand.

Security Considerations

The distribution layer is often a valuable security control point because traffic from multiple access networks passes through it. Organizations can apply ACLs, routing policies, VLAN controls, authentication, and monitoring at these boundaries.

However, if a core or distribution device is compromised, its higher position may provide access to many parts of the network. Administrative access to these devices must therefore be strongly protected.

Physical and Logical Topology Example

Consider an office where 50 computers are physically connected to two switches. Physically, this looks like a star or extended-star design.

Logically, however, the network may be divided like this:

VLAN 10: Employees

VLAN 20: Finance

VLAN 30: Voice phones

VLAN 40: Guest Wi-Fi

VLAN 50: Network management

The physical cables do not tell the whole security story. Logical controls determine whether a finance computer can communicate with a guest device, whether a phone can reach an employee laptop, and whether a user can access a switch management interface.

This is why cybersecurity professionals must understand both physical and logical topology.

Topology and Attack Paths

An **attack path** is a route an attacker may use to move from an initial compromised system toward a more valuable target.

Phishing email



Employee laptop



Internal file server



Administrator account



Domain controller

A flat topology may allow the employee laptop to communicate directly with many internal systems. This gives an attacker more opportunities after the first compromise.

A segmented topology may force traffic through controlled points:

Employee VLAN → Firewall → Application server

Application server → Firewall → Database

Guest VLAN → Internet only

Now, even if the employee laptop is compromised, the attacker cannot automatically reach the database. They must pass through firewall rules, authentication controls, and monitoring systems.

Segmentation does not guarantee safety, but it can reduce the attacker's options and give defenders more time to detect and respond.

Choke Points and Monitoring

A **choke point** is a location through which important traffic passes. Choke points are useful for applying security controls and collecting logs.

Examples include:

- Internet firewalls.
- Inter-VLAN firewalls.
- VPN gateways.
- Proxy servers.
- Core routers.
- Data-center gateways.
- Cloud transit gateways.

Security teams may place IDS/IPS sensors, network taps, packet brokers, or log collectors near these points. Centralized monitoring is easier when traffic follows predictable paths.

However, relying on only one choke point can be dangerous. Encrypted traffic, direct cloud connections, wireless networks, and unmanaged devices may bypass it. A strong design uses multiple layers of visibility rather than assuming all traffic passes through one device.

Single Points of Failure

A **single point of failure** is a device, link, service, or location whose failure can interrupt the network.

Examples include:

- One central switch.
- One internet connection.
- One firewall.
- One DNS server.
- One authentication server.
- One VPN gateway.
- One power source.

- One routing path.

Cybersecurity is not only about preventing unauthorized access. Availability is also part of security. If a firewall fails during an attack or a single switch goes offline, business operations may stop.

Organizations reduce single points of failure through:

- Redundant switches.
- High-availability firewalls.
- Multiple internet providers.
- Backup power.
- Multiple DNS resolvers.
- Redundant routing paths.
- Configuration backups.
- Tested failover procedures.

Redundancy should be secured carefully. A backup device with outdated firmware or weak configuration may become an attacker's alternative entry point.

Secure Topology Design

A secure topology should follow several principles:

1. **Separate systems by function and sensitivity.** Keep guest devices, user endpoints, servers, management systems, and critical data in different zones.
2. **Allow only required communication.** Use least privilege for network access instead of allowing every system to communicate with every other system.
3. **Place controls at trust boundaries.** Use firewalls, ACLs, authentication, and monitoring between zones.
4. **Protect management networks.** Administrative interfaces should not be exposed to ordinary users or the public internet.
5. **Use redundancy for critical services.** Provide backup paths and devices, but secure and test them.
6. **Monitor important traffic points.** Collect logs from firewalls, switches, routers, VPNs, DNS, DHCP, and cloud gateways.

7. **Document the network.** Keep diagrams, IP ranges, VLAN lists, device owners, firewall rules, and data flows updated.
8. **Use Zero Trust principles.** Do not trust traffic automatically just because it comes from an internal network.

What Is a Firewall?

A firewall is one of the most important security controls in a computer network. Its job is to monitor network traffic and decide which connections should be allowed, blocked, or recorded. It acts like a security guard standing at the entrance of a building. The guard checks who is entering, where they want to go, and whether they have permission. In the same way, a firewall examines network connections and applies security rules before allowing traffic to pass.

A firewall can protect a home network from internet threats, an office network from unauthorized access, internal servers from employee devices, cloud applications from unwanted connections, and individual computers from suspicious traffic. However, a firewall is not a complete security solution by itself. It works together with strong authentication, endpoint protection, encryption, patch management, security monitoring, backups, and employee awareness.

How a Firewall Works

Whenever data moves between networks or devices, it passes through a series of packets. A firewall examines these packets and makes a decision based on the security policy configured by the administrator.

The firewall may check the source IP address, destination IP address, source port, destination port, protocol, connection state, application, user identity, and sometimes the content of the traffic. It can also compare an IP address or domain with threat-intelligence information to determine whether it is known to be malicious.

For example, an organization may create rules such as:

Allow employees to access websites using HTTPS.

Allow administrators to connect to servers using SSH.

Block internet users from connecting directly to internal databases.

Allow DNS queries only through approved DNS servers.

Log all denied connections.

The firewall compares every connection with these rules. If the traffic matches an allow rule, it is permitted. If it matches a deny rule, it is blocked. If no rule matches, the firewall follows its default behavior.

A secure environment commonly uses a **default-deny** policy. This means traffic is blocked unless there is a specific business reason to allow it. This approach is safer than allowing everything and trying to block threats later.

Example of Firewall Traffic

Imagine that a user visits a secure website. The connection may look like this:

Source IP: 192.168.1.25

Source port: 52000

Destination IP: 203.0.113.20

Destination port: 443

Protocol: TCP

The user's computer is using a temporary source port, 52000, to connect to the web server's HTTPS service on port 443. The firewall checks whether outbound HTTPS traffic is permitted. If the rule allows TCP port 443, the connection continues.

Now imagine that an unknown device on the internet tries to connect directly to an internal database on TCP port 3306. The firewall should block this connection because databases should not normally be exposed directly to the public internet.

This is how a firewall reduces unnecessary exposure. It does not need to understand every detail of the business application; it can begin by controlling which devices, ports, and networks are allowed to communicate.

Inbound and Outbound Traffic

Inbound traffic is traffic entering a network from an external source. For example, someone accessing a public website, an administrator connecting through a VPN, or an internet user sending mail to a company mail server.

Outbound traffic is traffic leaving the network. Examples include an employee browsing the internet, a server downloading updates, or a compromised computer communicating with an attacker's command-and-control server.

Many people think of a firewall mainly as protection against incoming attacks. That is important, but outbound traffic is equally valuable from a security perspective. If malware infects a computer, it may try to connect to an attacker's server, download additional tools, or send stolen data outside the organization. Outbound firewall rules and monitoring can help detect or restrict this behavior.

Firewall Rules

Firewall rules are the instructions that tell the firewall what to do with traffic. A typical rule might look like this:

Source: 10.10.10.0/24

Destination: 10.10.20.10

Protocol: TCP

Port: 443

Action: Allow

Logging: Enabled

This rule allows devices in the `10.10.10.0/24` network to connect to the server `10.10.20.10` using HTTPS.

A good firewall rule should be specific, necessary, documented, regularly reviewed, and based on the principle of least privilege. It should allow only the traffic that is actually required.

A rule such as this is extremely risky:

Source: Any

Destination: Any

Protocol: Any

Port: Any

Action: Allow

It gives almost every device permission to communicate with every other device. Although such a rule may solve a connectivity problem quickly, it removes much of the firewall's security value.

Stateless Packet-Filtering Firewall

A stateless packet-filtering firewall examines each packet individually. It usually looks at the source IP address, destination IP address, protocol, and port.

For example, it may use rules such as:

Allow TCP traffic to port 443.

Deny TCP traffic to port 23.

This type of firewall does not remember earlier packets and does not understand whether a packet belongs to an established connection. It simply examines the packet in front of it and applies the rules.

Stateless firewalls are fast, simple, and useful for basic filtering. They are often found in routers and operating systems. However, they have limited context. They may not understand application behavior, session history, or whether an allowed service is being abused.

For example, if TCP port 443 is allowed, a stateless firewall may allow the traffic even if the service is being used for malicious activity. It only knows that the traffic matches the permitted address, protocol, and port.

Stateful Firewall

A stateful firewall keeps track of active network connections. It maintains a state table containing details such as the source and destination addresses, ports, protocol, and current connection status.

Suppose a user inside the network opens a secure website. The stateful firewall records that the internal user started the connection. When the web server sends a response, the firewall recognizes the response as part of an existing, legitimate session.

If an unknown external device sends a packet that does not belong to an established connection, the firewall can block it. This allows the firewall to understand context rather than treating every packet as an unrelated event.

Stateful firewalls are more practical and secure than basic stateless filtering for most modern networks because they track sessions and can block unsolicited inbound traffic. Stateful inspection is a foundation of many enterprise and home firewalls.

Proxy Firewall

A proxy firewall acts as an intermediary between the client and the destination server.

Client → Proxy Firewall → Internet Server

The client does not communicate directly with the internet server. Instead, the proxy receives the request, examines it, and creates a separate connection to the destination.

Because it operates closer to the application level, a proxy can understand protocols such as HTTP, FTP, DNS, or SMTP. It may inspect web requests, filter content, hide internal addresses, enforce browsing policies, and record detailed activity.

The disadvantage is that proxy firewalls may introduce some delay and require more processing power. They also need protocol-specific configuration and may have compatibility issues with certain applications.

Next-Generation Firewall

A **Next-Generation Firewall**, commonly called an NGFW, combines traditional firewall functions with advanced security capabilities. A traditional firewall may make decisions mainly based on IP addresses and ports. An NGFW can also identify applications, users, content, and threats.

Typical NGFW features include:

- Stateful inspection.
- Application awareness.
- User-based policies.
- Deep packet inspection.
- Intrusion prevention.
- Malware detection.
- Threat-intelligence integration.
- URL filtering.
- TLS inspection.
- Data-loss controls.
- Detailed reporting.

For example, a traditional firewall may allow all traffic over TCP port 443 because HTTPS uses that port. An NGFW may be able to identify the applications using that connection and apply more specific rules.

It could allow an approved business application, block a risky application, detect an exploit attempt, or stop communication with a known malicious destination. NGFWs

provide more visibility and control than traditional firewalls, although they still require careful configuration and monitoring.cisco+1

Web Application Firewall

A **Web Application Firewall**, or WAF, is designed specifically to protect web applications and APIs. It examines HTTP and HTTPS requests and looks for suspicious patterns.

A WAF can help detect and block attacks such as:

- SQL injection.
- Cross-site scripting.
- Malicious file uploads.
- Path traversal.
- HTTP protocol abuse.
- Automated bot activity.
- Some application-layer denial-of-service attacks.

A normal network firewall may allow HTTPS traffic to a web server because port 443 is required. A WAF examines what is inside the web request. For example, if an attacker enters database commands into a login field, the WAF may recognize the request as suspicious and block it.

A WAF is helpful, but it does not replace secure programming, code reviews, vulnerability testing, patching, input validation, or strong authentication. It should be treated as an additional layer of protection rather than the only defense.

Host-Based Firewall

A host-based firewall runs directly on an individual computer or server. Windows Firewall, Linux firewall tools, and firewall controls included in endpoint-security products are examples.

A host-based firewall can control which applications are allowed to communicate, which ports are open, which IP addresses can connect, and whether inbound or outbound traffic should be permitted.

Host firewalls are valuable because they protect the device even when it leaves the organization's network. A laptop connected to public Wi-Fi can still enforce its local firewall rules.

They also provide a second layer of defense. Even if an attacker bypasses a network firewall, the host firewall may prevent unauthorized access to a local service.

Network-Based Firewall

A network-based firewall protects an entire network, subnet, or security zone. It may be placed between the internet and the internal network, between employee devices and servers, between guest Wi-Fi and corporate systems, or between a data center and a cloud environment.

Network firewalls provide centralized control. Instead of configuring the same policy separately on hundreds of computers, administrators can apply a common policy at a central point.

However, network firewalls cannot see every connection. Traffic may move directly between two endpoints, through an unmanaged device, over a private cloud connection, or through an encrypted tunnel. This is why organizations often use both network-based and host-based firewalls.

Firewall Zones

Firewalls often divide networks into security zones. Each zone contains systems with similar security requirements.

Common zones include:

- **Untrusted zone:** The public internet.
- **DMZ:** Public-facing servers.
- **Internal zone:** Employee devices.
- **Server zone:** Business applications and databases.
- **Management zone:** Administrative systems.
- **Guest zone:** Visitor devices.

- **VPN zone:** Remote users or connected offices.

Traffic between these zones is controlled by firewall rules. For example, guest Wi-Fi users may be allowed to access the internet but denied access to employee laptops and internal servers.

This design is safer than placing every system into one flat network. If an attacker compromises a guest device, segmentation can prevent the attacker from directly reaching critical systems.

NAT and Firewalls

NAT stands for **Network Address Translation**. It changes private IP addresses into public IP addresses and is commonly performed by home and enterprise firewalls.

For example:

Internal device: 192.168.1.25

Public address: 203.0.113.50

NAT allows many internal devices to share one public internet address. It can also make unsolicited inbound connections more difficult because outside systems do not automatically know the private addresses of internal devices.

However, NAT is not the same as a firewall. NAT changes addresses; a firewall enforces security policies. Organizations must still create explicit rules to control traffic. Relying on NAT alone is not a safe security strategy.

VPN and Firewall Relationship

Many firewalls also provide VPN services. A VPN creates an encrypted connection for remote workers, branch offices, or cloud environments.

A firewall handling VPN access may authenticate the user, verify MFA, assign a VPN address, apply access rules, limit access to specific applications, record activity, and disconnect suspicious sessions.

One common mistake is giving every VPN user unrestricted access to the entire internal network. A safer approach is to provide only the resources required for that person's role. For example, an employee may need access to a payroll application but not to server-management interfaces.

A VPN provides secure transport, but it does not automatically make the connected user or device trustworthy. The device should still be patched, protected, authenticated, and monitored.

Firewall, IDS, IPS, and SIEM

Firewalls, IDS, IPS, and SIEM systems have different roles.

A **firewall** allows or blocks traffic according to security policy.

An **IDS**, or Intrusion Detection System, monitors activity and alerts security teams when it sees suspicious behavior.

An **IPS**, or Intrusion Prevention System, can actively block or disrupt recognized malicious traffic.

A **SIEM**, or Security Information and Event Management platform, collects and correlates logs from firewalls, servers, endpoints, identity systems, and other security tools.

For example, a firewall may allow HTTPS traffic to a web server. An IPS may inspect that traffic and identify an exploit attempt. The SIEM may then combine that alert with web-server logs and authentication records to determine whether the attack succeeded.

These tools are most effective when they work together. A firewall provides control, IDS and IPS provide detection and prevention, and the SIEM helps security analysts understand the larger story.

Firewall Logging

Firewall logs record important events such as allowed connections, blocked traffic, rule matches, and suspicious activity.

A log entry might look like this:

text

Time: 2026-09-10 12:30:00

Source IP: 198.51.100.25

Destination: 10.10.20.10

Protocol: TCP

Port: 22

Action: Denied

Rule: Block Internet SSH

Security teams use firewall logs to investigate incidents, identify port scanning, detect repeated connection attempts, confirm that a rule is working, troubleshoot network problems, and find compromised devices making unusual outbound connections.

Logging every single event without a plan can create too much noise. Organizations should identify important events, send useful logs to a SIEM, protect the logs from tampering, and retain them according to business and legal requirements.

Firewall Rule Order

Many firewalls evaluate rules from top to bottom. The first rule that matches the traffic usually determines the result.

Consider these rules:

1. Allow 10.10.10.0/24 to 10.10.20.10 on TCP 443
2. Deny all traffic to 10.10.20.10

The first rule permits the required HTTPS traffic, while the second rule blocks all other traffic to the server.

If the deny rule were placed first, it would block the HTTPS traffic before the firewall reached the allow rule. This is why rule order must be reviewed carefully.

Security teams also look for **shadowed rules**, which are rules that can never be reached because an earlier rule always matches first. Unused, duplicate, and overly broad rules should be removed or corrected.

Common Firewall Mistakes

A firewall can be powerful, but poor configuration can make it ineffective. Common mistakes include allowing traffic from any source to any destination, leaving old rules active, exposing administrative ports to the internet, forgetting to enable logging, allowing unnecessary outbound traffic, and using weak administrator passwords.

Other problems include failing to patch the firewall, not reviewing VPN accounts, creating permanent exceptions for temporary needs, ignoring IPv6 rules, assuming internal traffic is automatically safe, failing to back up configurations, and not testing failover.

A firewall should be treated as a living security control. Its rules must change as the organization's systems, applications, users, and risks change.

Firewall in a Real Network

Consider a company with this network structure:

Internet



Perimeter Firewall



DMZ: Web and Mail Servers



Internal Firewall



Employee Network, Application Network, Database Network

The perimeter firewall allows internet users to access the public web server over HTTPS. The web server can communicate with the application server only through the required application port. The application server can connect to the database only through the required database port.

Employees cannot directly connect to the database, and guest Wi-Fi cannot access internal systems. If the public web server is compromised, the attacker still faces firewall restrictions before reaching the application and database networks.

This is the value of defense in depth. One control may fail, but multiple controls make it more difficult for an attacker to reach critical assets.

Firewall and Cybersecurity Roles

Different cybersecurity professionals work with firewalls in different ways.

Network security engineers design firewall architecture, create rules, connect security zones, and plan high availability.

SOC analysts investigate firewall alerts, blocked traffic, unusual connections, and repeated scanning attempts.

Penetration testers assess whether unauthorized services are exposed and whether firewall rules can be bypassed within an approved scope.

Blue teams improve segmentation, firewall policies, monitoring, and response procedures.

Incident responders review firewall logs to understand how an attack entered the environment and which systems it contacted.

Cloud security engineers manage virtual firewalls, security groups, network ACLs, and cloud routing controls.

GRC professionals review firewall policies to ensure that security requirements and compliance obligations are being met.

Final Understanding

A firewall is not simply a wall that blocks everything. It is a decision-making security control that examines network traffic, compares it with a defined policy, and decides whether the traffic should pass, be blocked, or be logged.

A strong firewall strategy includes:

- Least-privilege rules.
- Network segmentation.
- Secure administrative access.
- Inbound and outbound filtering.
- Logging and monitoring.
- Regular rule reviews.
- Configuration backups.
- Redundant systems.
- Integration with IDS, IPS, SIEM, endpoint security, and identity controls.

The most important idea is that a firewall controls the paths through which network traffic can travel. Good security design ensures that even if one system or path is compromised, an attacker cannot easily move throughout the entire environment.

ACLs, Network Segmentation, and DMZs:

ACLs, Network Segmentation, and DMZs

Access Control Lists, network segmentation, and DMZs are closely connected. An ACL decides which traffic is allowed or denied, segmentation divides the network into

separate areas, and a DMZ creates a controlled zone for systems that must be reachable from outside. Together, they help limit unauthorized access and reduce the damage caused by a compromised device.

4. Access Control Lists

What Is an ACL?

An **Access Control List**, or ACL, is an ordered collection of rules used to control traffic. These rules tell a router, switch, firewall, cloud platform, or application what traffic should be allowed and what traffic should be blocked.

An ACL can examine details such as:

- Source IP address.
- Destination IP address.
- Protocol, such as TCP, UDP, or ICMP.
- Source port.
- Destination port.
- Direction of traffic.
- Interface where traffic enters or leaves.
- Sometimes the user, application, or security identity.

A simple ACL might say:

text

Allow 10.10.10.0/24 to access 10.10.20.10 using TCP port 443

Deny all other traffic to 10.10.20.10

In plain English, this means that devices from the 10.10.10.0/24 network can access the server 10.10.20.10 over HTTPS, but other types of traffic are not allowed.

ACL as a Security Guard

Think of an ACL as a security guard with a written guest list.

The guard checks:

1. Who is trying to enter?
2. Where are they trying to go?
3. What are they trying to do?
4. Are they allowed to do it?
5. Should the attempt be recorded?

If the request matches an allow rule, the traffic passes. If it matches a deny rule, the traffic is blocked. If it does not match any rule, the device follows its default behavior.

On many network devices, an ACL has an **implicit deny** at the end. This means that traffic not explicitly permitted is automatically denied.

How ACL Processing Works

Suppose an ACL contains these rules:

1. Allow 10.10.10.0/24 to 10.10.20.10 on TCP port 443
2. Deny 10.10.10.0/24 to 10.10.20.10 on TCP port 22
3. Deny all traffic to 10.10.20.10

When traffic arrives, the device checks rule 1 first.

- If the traffic is HTTPS from 10.10.10.0/24, rule 1 allows it.
- If the traffic is SSH from 10.10.10.0/24, rule 1 does not match, so the device checks rule 2 and blocks it.
- If the traffic is anything else going to 10.10.20.10, rule 3 blocks it.

The order is important because the first matching rule wins.

Why Rule Order Matters

Consider this ACL:

1. Allow 10.10.10.0/24 to 10.10.20.10

2. Deny 10.10.10.50 to 10.10.20.10

The second rule will never work for 10.10.10.50. The first rule already allows the entire 10.10.10.0/24 network, including 10.10.10.50.

The correct order would be:

1. Deny 10.10.10.50 to 10.10.20.10

2. Allow 10.10.10.0/24 to 10.10.20.10

The specific rule must appear before the broad rule. This is one of the most common ACL mistakes. A broad permit placed too early can accidentally override a more specific deny rule.

Example: Controlling Server Access

Imagine that a company has:

Employee network: 10.10.10.0/24

Application server: 10.10.20.10

Database server: 10.10.30.10

The company wants employees to access the application server over HTTPS, but employees should not directly access the database.

The ACL might look like:

Allow 10.10.10.0/24 to 10.10.20.10 on TCP 443

Deny 10.10.10.0/24 to 10.10.30.10 on any protocol

Deny all other unnecessary traffic

This design forces users to access the application instead of connecting directly to the database. The application server becomes the controlled middle layer.

Standard and Extended ACLs

In traditional networking, ACLs are often described as **standard** or **extended**.

A **standard ACL** usually makes decisions mainly based on the source IP address. It is simple but less precise.

An **extended ACL** can usually filter by source IP, destination IP, protocol, and port. It provides much more control.

For example, a standard ACL may say:

```
Allow traffic from 10.10.10.0/24
```

An extended ACL may say:

```
Allow traffic from 10.10.10.0/24
```

```
to 10.10.20.10
```

```
using TCP port 443
```

Extended rules are more useful for cybersecurity because they allow administrators to define exactly which communication is necessary.

Inbound and Outbound ACLs

An ACL can be applied to traffic entering or leaving an interface.

An **inbound ACL** examines traffic as it enters an interface. It can block unwanted traffic before the device processes or routes it further.

An **outbound ACL** examines traffic before it leaves an interface. It can control what traffic is allowed to travel toward a destination network.

The best placement depends on the network design and the type of rule. In general, unwanted traffic should be stopped as early as practical, but administrators must also avoid blocking legitimate communication before it reaches the correct destination.

ACL Logging

Logging helps administrators understand which rules are being used and which traffic is being denied.

For example:

Time: 2026-09-10 12:45:00

Source IP: 198.51.100.25

Destination: 10.10.20.10

Protocol: TCP

Port: 22

Action: Denied

Rule: Block Internet SSH

This record tells the security team that an external device attempted to access SSH on an internal server.

ACL logs can help detect:

- Port scanning.
- Repeated unauthorized access.
- Misconfigured applications.
- Malware connections.
- Attempts to reach sensitive systems.
- Policy violations.

However, logging every packet may create excessive noise. It is better to log meaningful denials, high-risk services, administrative access, and unusual behavior.

ACL Best Practices

A good ACL should follow these principles:

Use least privilege

Allow only the traffic that is required. If an application needs HTTPS access to a server, do not automatically allow every protocol and port.

Be specific

Define exact source networks, destination systems, protocols, and ports whenever possible.

Put specific rules before broad rules

A narrow exception should appear before a general permit or deny rule.

Document the purpose

Every rule should explain why it exists, who requested it, and which application or business process depends on it.

Review rules regularly

Remove rules that are no longer needed. Old rules often remain after applications or employees are removed.

Use temporary expiration dates

A temporary access rule should have an expiration or review date. Temporary exceptions can become permanent security weaknesses.

Protect administrative access

Only authorized administrators should be able to modify ACLs. Use MFA, secure management networks, logging, and role-based access.

Test changes carefully

A small ACL mistake can block a business application or expose a sensitive server. Changes should be tested, approved, documented, and monitored.

5. Network Segmentation

What Is Network Segmentation?

Network segmentation means dividing a large network into smaller sections and controlling communication between them.

Instead of putting every device into one flat network, an organization creates separate areas based on function, sensitivity, or trust level.

For example:

Employee devices

Finance systems

Application servers

Database servers

Guest Wi-Fi

Development systems

Management systems

Backup systems

Each area can have its own IP range, VLAN, firewall policy, authentication requirements, and monitoring.

Why Segmentation Matters

Imagine an office with 500 devices on one flat network. If one laptop is infected with malware, the attacker may be able to scan and communicate with hundreds of other devices.

Now imagine the same company divided into separate zones. The compromised laptop may be allowed to access only a few business applications. It may not be able to connect directly to finance servers, domain controllers, backup systems, or network-management interfaces.

Segmentation limits **lateral movement**, which is the attacker's movement from one compromised system to another.

It does not necessarily stop the initial compromise, but it can prevent a small incident from becoming a company-wide breach.

Physical and Logical Segmentation

Physical segmentation uses separate hardware or cables. For example, a company may use one physical network for production systems and another for building-management systems.

Logical segmentation uses technologies such as VLANs, subnets, firewall rules, VRFs, security groups, or software-defined networking. Devices may share physical switches but remain logically separated.

Logical segmentation is flexible and cost-effective, but it must be configured correctly. Simply placing devices in different VLANs does not guarantee security. Routing and firewall controls must also restrict communication between those VLANs.

VLAN-Based Segmentation

A VLAN creates a separate logical network on a switch.

For example:

VLAN 10: Employees

VLAN 20: Finance

VLAN 30: Servers

VLAN 40: Guest Wi-Fi

VLAN 50: Network management

Devices in the same VLAN may communicate through switching. Devices in different VLANs require routing, and that routing should be controlled by ACLs or firewalls.

A secure design might allow:

Employees → Application servers: TCP 443

Application servers → Database servers: Required database port

Guests → Internet: Allowed

Guests → Internal systems: Blocked

Employees → Management interfaces: Blocked

Administrators → Management interfaces: Allowed

This is much safer than allowing every VLAN to communicate freely.

Microsegmentation

Microsegmentation applies access rules at a more detailed level, often down to individual workloads, applications, virtual machines, containers, or identities.

For example, two servers may be on the same physical host but have different security policies. One server may be allowed to communicate with a database, while another server on the same host is denied.

Microsegmentation is especially useful in cloud and data-center environments where traditional network boundaries may not be sufficient.

Segmentation and Trust Levels

A useful way to design segments is to think about trust and sensitivity.

A guest Wi-Fi network is usually low trust. It should have access to the internet but not to internal systems.

An employee network has more trust, but employee devices can still become infected or compromised.

A server network may contain important business applications and therefore require stricter controls.

A database network may contain highly sensitive information and should accept connections only from approved application servers.

A management network should be accessible only to authorized administrators.

Trust should not be automatic. Internal placement alone does not mean a system should have unrestricted access.

Segmentation and Zero Trust

Traditional networks often assume that internal traffic is safe. Modern security designs increasingly follow Zero Trust principles.

Zero Trust means:

- Verify identity explicitly.
- Use least privilege.
- Assume that a breach may already have occurred.

- Continuously monitor access.
- Do not trust a device only because it is inside the network.

In practice, an employee laptop may need to prove its identity and security status before accessing a sensitive application. Access can be limited to a specific user, device, application, time, and purpose.

Common Segmentation Mistakes

Segmentation can fail when organizations create separate networks but do not control traffic between them.

Common mistakes include:

- Allowing all traffic between VLANs.
- Leaving old firewall rules active.
- Giving users direct access to databases.
- Allowing guest devices to reach internal services.
- Placing management interfaces on user networks.
- Forgetting wireless networks.
- Ignoring cloud and remote-access paths.
- Not monitoring traffic between segments.
- Using one administrator account everywhere.
- Creating segments without documenting their purpose.

A segment is useful only when the communication rules enforce the intended separation.

6. DMZ and Security Zones

What Is a DMZ?

A **DMZ**, or demilitarized zone, is a separate network used for systems that must be reachable from outside the internal network.

Common DMZ systems include:

- Public web servers.
- Mail gateways.
- Public DNS servers.
- Reverse proxies.
- VPN gateways.
- Application gateways.
- Internet-facing APIs.

A typical design looks like this:

Internet



Perimeter firewall



DMZ



Internal firewall



Internal network

The DMZ creates a buffer between the public internet and the trusted internal network.

Why a DMZ Is Important

A public-facing server has a higher risk of attack because it must accept connections from external users. If that server is placed directly inside the internal network, a successful compromise could give an attacker a direct starting point for attacking employee devices, file servers, domain controllers, and databases.

When the server is placed in a DMZ, the organization can restrict what it is allowed to do. The web server may receive HTTPS traffic from the internet, but it may not be allowed to initiate arbitrary connections to the internal network.

The DMZ does not make a public server invulnerable. Instead, it limits the consequences if the server is compromised.

Example of a DMZ Policy

Suppose a company has a public web server, an application server, and a database server.

The security policy might be:

text

Internet → Web server: TCP 443 allowed

Web server → Application server: Required application port allowed

Application server → Database server: Required database port allowed

Web server → Employee network: Denied

Web server → Management network: Denied

Internet → Database server: Denied

Internet → Employee network: Denied

The internet does not communicate directly with the database. The web server does not need direct access to employee laptops. Each connection is limited to the smallest amount necessary.

Two-Firewall DMZ Design

Some organizations use two firewalls:

Internet



External firewall



DMZ



Internal firewall



Internal network

The external firewall protects the DMZ from the internet. The internal firewall protects the internal network from both the internet and the DMZ.

This design creates two separate enforcement points. If an attacker compromises a DMZ server, they still have to pass through the internal firewall before reaching internal systems.

Single-Firewall DMZ Design

A single firewall can also create multiple interfaces or zones:

Internet interface

DMZ interface

Internal interface

The firewall controls traffic between all three areas. This design can be effective if the firewall is correctly configured, securely administered, monitored, patched, and deployed with redundancy.

The number of firewalls is less important than the quality of the security policy. A poorly configured two-firewall design can be weaker than a well-managed single-firewall design.

DMZ Security Rules

A secure DMZ generally follows these principles:

Allow only required inbound traffic

If a web server needs HTTPS, allow TCP port 443. Do not expose SSH, database ports, file-sharing ports, or management services to the entire internet.

Restrict outbound traffic

A compromised DMZ server should not be able to make unrestricted outbound connections. Restrict DNS, time synchronization, updates, and application connections to approved destinations.

Block direct DMZ-to-internal access

By default, DMZ systems should not connect directly to internal employee devices, domain controllers, management systems, or backup networks.

If a required communication exists, create a narrow exception for the exact source, destination, protocol, and port.

Protect management access

Administrators should manage DMZ systems through a dedicated management network, secure bastion host, VPN, MFA, and strong logging rather than exposing administrative services publicly.

Monitor the zone

Collect firewall, operating-system, application, authentication, DNS, and web-server logs from DMZ systems. Alerts should focus on unusual outbound connections, failed logins, unexpected services, and traffic toward internal networks.

DMZ and Application Architecture

A modern web application may use several layers:

Internet



WAF or CDN



Web tier



Application tier



Database tier

The web tier handles public requests. The application tier performs business logic. The database tier stores sensitive information.

Each layer should have its own security controls. The web tier may accept HTTPS from the internet, while the application tier accepts traffic only from the web tier. The database accepts traffic only from approved application servers.

This layered architecture reduces direct exposure and makes it easier to identify abnormal communication.

DMZ and Mail Servers

Mail systems often use a gateway or filtering service in the DMZ. The gateway receives messages from the internet, scans them for spam and malware, and forwards legitimate messages to the internal mail system.

This prevents the internal mail server from being directly exposed to every internet connection. The gateway should communicate with internal mail systems only through required protocols and approved destinations.

DMZ and VPN Gateways

A VPN gateway may be placed in a perimeter or DMZ zone because it must accept connections from remote users. After authentication, users should not automatically receive unrestricted access to the internal network.

VPN access should be based on:

- User identity.
- Role.
- Device health.
- MFA.
- Required application.
- Network location.
- Risk level.

For example, a contractor may need access to one project application but not to internal file servers or administrator systems.

Security Zones

Security zones are broader areas created according to function, sensitivity, and trust. Common zones include:

Internet or untrusted zone

This is the public network. Traffic from this zone should be treated as potentially hostile.

DMZ zone

This contains public-facing systems that need controlled external access.

User zone

This contains employee laptops, desktops, and mobile devices. These systems are important but may be exposed to phishing, malware, and user mistakes.

Server zone

This contains internal applications and infrastructure services. Access should be restricted to approved users and systems.

Database zone

This contains sensitive databases and should accept connections only from approved application servers.

Management zone

This contains network-device interfaces, hypervisors, administrative consoles, and security tools. Access should be restricted to authorized administrators.

Guest zone

This provides internet access to visitors or unmanaged devices. It should be isolated from internal systems.

Backup zone

This contains backup servers and storage. It should be protected from ordinary user access because attackers often target backups during ransomware attacks.

How ACLs, Segmentation, and DMZ Work Together

These three concepts support one another.

Segmentation creates separate networks.

Security zones define the purpose and trust level of those networks.

ACLs and firewalls control traffic between them.

For example:

Guest VLAN → Internet: Allow

Guest VLAN → Internal servers: Deny

Employee VLAN → Web application: Allow TCP 443

Employee VLAN → Database: Deny

Web server in DMZ → Application server: Allow required port

Web server in DMZ → Internal employee network: Deny

Application server → Database: Allow required database port

Internet → Database: Deny

Without segmentation, the ACLs have fewer boundaries to protect. Without ACLs, segmentation may provide only an appearance of separation. Without security zones, it is difficult to design consistent policies.

What Happens If a DMZ Server Is Compromised?

Imagine an attacker exploits a vulnerability in a public web server. The attacker now controls that server.

In a poorly designed network, the web server may be able to:

- Scan employee devices.
- Connect to databases.
- Access domain controllers.
- Reach backup servers.
- Connect to management interfaces.
- Steal internal credentials.

In a well-designed network, the compromised server may be limited to:

- Receiving HTTPS traffic.
- Communicating with one application server.
- Resolving DNS through one approved resolver.
- Synchronizing time with an approved server.
- Sending logs to a monitoring system.

The attacker may still cause harm, but segmentation and ACLs make lateral movement much more difficult. This gives defenders more time to detect, contain, and remove the threat.

Practical Design Example

Consider a company with these networks:

VLAN 10: Employees

VLAN 20: Finance

VLAN 30: Application servers

VLAN 40: Database servers

VLAN 50: Guest Wi-Fi

VLAN 60: Management

DMZ: Public web servers

The rules might be:

Employees → Application servers: TCP 443 allowed

Finance → Finance application: Required ports allowed

Application servers → Database servers: Required database port allowed

Web servers → Application servers: Required application port allowed

Guests → Internet: Allowed

Guests → Internal networks: Denied

Employees → Management interfaces: Denied

Administrators → Management interfaces: Allowed

DMZ → Employee networks: Denied

Internet → Database servers: Denied

The important point is that communication is based on business requirements, not convenience.

Common Design Errors

A network may appear segmented but still be insecure if:

- The firewall allows any-to-any traffic between zones.
- The DMZ can access the internal network freely.
- Database servers have public IP addresses.

- Management interfaces are reachable from user networks.
- Guest Wi-Fi shares the same internal routing path.
- Firewall exceptions are undocumented.
- The organization does not monitor inter-zone traffic.
- Backup systems are reachable from ordinary user devices.
- A VPN provides full network access to every user.
- IPv6 traffic is not covered by the same security policy.

These mistakes create hidden paths that attackers can exploit.

Final Understanding

ACLs, segmentation, and DMZs are not separate ideas; they are parts of one security design.

An ACL answers:

Which traffic should be allowed or denied?

Segmentation answers:

Which systems should be placed in separate networks?

A DMZ answers:

Where should public-facing systems be placed so they are separated from internal systems?

A secure network does not assume that every internal system is trustworthy. It divides systems into appropriate zones, allows only necessary communication, blocks unnecessary paths, monitors important traffic, and protects administrative access.

The overall goal is not merely to stop every attack at the perimeter. The goal is to make the network difficult to move through after a compromise. If one device is breached, strong ACLs, segmentation, and DMZ controls can prevent that breach from spreading to the organization's most valuable systems.

VPNs, Monitoring, Wireshark, IDS/IPS, Proxies, TLS, and AAA:

These topics are closely connected. A VPN provides secure remote access, monitoring helps security teams see what is happening, Wireshark helps them inspect traffic, IDS and IPS detect or block attacks, proxies control communication, TLS encrypts data, and AAA controls who can access systems and what they are allowed to do.

A strong network-security design uses all of these controls together rather than depending on one technology.

7. VPNs and Secure Remote Access

What Is a VPN?

A **VPN**, or Virtual Private Network, creates an encrypted connection between a device and another network across an untrusted network such as the internet.

When an employee works from home, their laptop may be connected to a home Wi-Fi network and an internet service provider that the company does not control. A VPN creates a protected tunnel between the employee's device and the organization's VPN gateway.

text

Employee laptop → Internet → VPN gateway → Company network

Without a VPN, traffic may travel directly across the internet. With a VPN, the traffic is encrypted between the VPN endpoints.

The VPN provides protection for the connection, but it does not automatically make the user or device trustworthy. If the employee's laptop is infected with malware, the VPN may securely connect that infected laptop to the company network. This is why VPN

access must be combined with MFA, endpoint protection, device checks, limited permissions, and monitoring.media.defense+1

How a VPN Works

A VPN usually performs several steps:

1. The user's device contacts the VPN gateway.
2. The gateway verifies the user's identity.
3. The user may complete MFA.
4. The VPN endpoints negotiate encryption settings.
5. An encrypted tunnel is created.
6. The user receives a VPN address.
7. Firewall and access rules determine which internal resources are available.
8. The organization records the session and network activity.

The encryption protects the traffic while it travels across the untrusted network. Anyone observing the connection may see that a VPN session exists, but they should not be able to read the protected content inside the tunnel.

Remote-Access VPN

A **remote-access VPN** connects one user or device to an organization's network.

For example, a remote employee may use a VPN client on their laptop to access:

- Internal applications.
- File shares.
- Email systems.
- Development environments.
- Administrative tools.
- Private cloud resources.

The VPN gateway acts as the controlled entry point. The company can require MFA, check the device, assign the user to a specific access group, and limit access to only the applications required for the person's role.

A common mistake is giving a remote user full access to the entire internal network. If that user's credentials or device are compromised, the attacker may gain broad access. A safer approach is to use least privilege and application-specific access.

Site-to-Site VPN

A **site-to-site VPN** connects two networks rather than one individual device to a network.

For example:

text

Branch office → Encrypted VPN tunnel → Headquarters

The branch office may communicate with internal applications at headquarters as if the two sites were connected through a private network.

Site-to-site VPNs are also used for:

- Connecting data centers.
- Connecting cloud and on-premises networks.
- Connecting business partners.
- Connecting branch offices.
- Protecting communication between distributed systems.

The security risk is that a site-to-site VPN may connect many devices at once. If one branch network is compromised, the attacker may attempt to move through the tunnel into the other network. Firewall rules and segmentation should therefore control communication across the VPN.

Common VPN Technologies

IPsec VPNs operate at the network layer and are commonly used for site-to-site connections and some remote-access systems.

SSL/TLS-based VPNs use TLS technology and are often delivered through a client application or web portal.

WireGuard is a modern VPN protocol known for a simpler design and efficient cryptography.

OpenVPN is a widely used VPN solution that uses TLS-based security.

The specific technology matters, but secure configuration matters just as much. Weak encryption, outdated software, poor authentication, exposed management interfaces, and unrestricted access can make a well-known VPN product unsafe.

VPN Security Controls

A secure VPN should use:

- Multi-factor authentication.
- Strong and unique credentials.
- Modern encryption.
- Regular software and firmware updates.
- Device-health checks.
- Endpoint protection.
- Least-privilege access.
- Short session lifetimes where appropriate.
- Account review and removal of inactive users.
- Detailed logging.
- Alerts for unusual login behavior.
- High-availability and backup connectivity.

Organizations should also monitor unusual VPN behavior, such as logins from unexpected countries, multiple simultaneous sessions, access outside normal working hours, repeated failed logins, and large data transfers.

Security guidance recommends protecting and monitoring VPN access, using logging and intrusion prevention, applying segmentation, and adding application-layer encryption for particularly sensitive data.[cyber.gc](https://www.cyber.gc.ca/en/secure-remote-access)

Split Tunneling

With **split tunneling**, only traffic intended for the organization travels through the VPN. Other internet traffic goes directly through the user's local connection.

This can improve performance and reduce the load on the VPN gateway. However, it also means that the organization may have less visibility into the user's other network traffic.

With **full tunneling**, all traffic passes through the VPN and may be inspected by company security controls. This provides greater visibility but uses more bandwidth and resources.

The correct choice depends on the organization's risk, privacy requirements, bandwidth, and device-management model.

8. Network Security Monitoring

What Is Network Monitoring?

Network security monitoring is the process of collecting, reviewing, and analyzing information about network activity.

It helps security teams answer questions such as:

- Which devices are communicating?
- What services are being accessed?
- Which users are logging in?
- Is a device behaving unusually?
- Is malware communicating externally?
- Is sensitive data leaving the network?
- Are attackers scanning internal systems?

Monitoring is not simply watching a screen for alerts. It involves collecting data, creating a picture of normal activity, identifying suspicious behavior, investigating events, and taking action.

Important Monitoring Sources

A security team may collect data from:

- Firewall logs.
- DNS queries.
- DHCP assignments.
- VPN connections.
- Proxy logs.
- Router and switch logs.
- NetFlow or IPFIX records.
- Endpoint detection systems.
- Packet captures.
- Authentication systems.
- Cloud network logs.
- Server and application logs.

Each source provides a different part of the story.

A firewall may show that a connection was blocked. DNS logs may show that the device looked up a suspicious domain. Endpoint logs may reveal that a script ran on the machine. Authentication logs may show that an unusual user logged in. When these events are combined, the security team can understand the incident more accurately.

What Is Normal Behavior?

Monitoring is most effective when the organization understands normal behavior.

For example:

- A payroll server may normally communicate with a database server.
- An employee laptop may normally contact email and web services.
- A printer may not normally communicate with a domain controller.

- A backup server may transfer large amounts of data during a scheduled window.
- An administrator may normally log in from a management network.

If a printer suddenly connects to an external command-and-control server, or an employee laptop contacts hundreds of unfamiliar IP addresses, the activity may be suspicious.

The same event can have different meanings depending on context. A large data transfer from a backup server may be normal, while the same transfer from an employee laptop may require investigation.

Network Flow Data

NetFlow and **IPFIX** provide metadata about communication flows. They usually record information such as:

- Source IP address.
- Destination IP address.
- Source port.
- Destination port.
- Protocol.
- Start and end time.
- Number of packets.
- Amount of data transferred.

Flow data usually does not contain the full content of packets, but it provides a broad view of who communicated with whom.

This makes it useful for identifying:

- Port scanning.
- Unusual outbound traffic.
- Large data transfers.
- Lateral movement.
- Suspicious long-running connections.
- Unexpected protocols.

- Communication with unfamiliar destinations.

Monitoring in a SOC

A **Security Operations Center**, or SOC, uses monitoring tools to detect and investigate threats.

A SOC analyst may receive an alert such as:

A workstation contacted 400 external IP addresses in 10 minutes.

The analyst may then check:

1. Which user was logged into the workstation?
2. What process created the connections?
3. What DNS queries did the device make?
4. Was malware detected?
5. Did the device access internal servers?
6. Was data transferred?
7. Are other devices showing similar behavior?

This process turns a single alert into a broader investigation.

Monitoring Challenges

Network monitoring can be difficult because of:

- Large volumes of data.
- Encrypted traffic.
- False positives.
- Missing logs.
- Poor time synchronization.
- Unmanaged devices.
- Cloud and remote networks.
- Attackers attempting to hide their behavior.
- Inconsistent log formats.

Organizations should synchronize system clocks, centralize important logs, protect log integrity, define retention periods, and create clear investigation procedures.

9. Packet Capture and Wireshark

What Is Packet Capture?

A packet capture is a recorded copy of network traffic. It allows an analyst to examine communication in detail rather than relying only on summary logs.

A packet may show:

- Source and destination addresses.
- Ports.
- Protocols.
- TCP flags.
- DNS names.
- TLS negotiation.
- Packet size.
- Timing.
- Retransmissions.
- Errors.
- Application data, if it is not encrypted.

Packet capture is valuable for troubleshooting, incident response, malware analysis, and security investigations.

What Is Wireshark?

Wireshark is a packet-analysis tool that displays captured network traffic in a readable format. It can decode many protocols and allow analysts to filter traffic by host, port, protocol, or conversation.

An analyst might use Wireshark to answer questions such as:

- Did the TCP connection complete?
- Which DNS server was contacted?
- Did a device send an unusual ARP request?
- What server did the client contact?
- Was the traffic encrypted?
- Were packets repeatedly retransmitted?
- Did the application return an error?

Wireshark is also useful for understanding how network protocols work in practice.

TCP Handshake in Wireshark

A normal TCP connection begins with a three-way handshake:

text

Client → Server: SYN

Server → Client: SYN-ACK

Client → Server: ACK

This establishes the connection.

If an analyst sees many SYN packets but very few SYN-ACK responses, possible explanations include:

- The destination is unreachable.
- A firewall is blocking the traffic.
- A service is not listening.
- A device is scanning many ports.
- A denial-of-service attack is occurring.
- There is a routing problem.

The packet capture alone may not prove which explanation is correct. Analysts compare it with firewall logs, system logs, routing information, and endpoint data.

DNS Analysis

Wireshark can show DNS requests and responses. An analyst may look for:

- Requests to suspicious domains.
- Very long or unusual subdomains.
- Frequent requests with random-looking names.
- Queries to unauthorized DNS servers.
- DNS responses containing unexpected addresses.
- A large number of failed lookups.

These patterns may indicate malware, DNS tunneling, misconfiguration, or a compromised device.

ARP Analysis

ARP traffic is normally local to a network. Analysts may examine ARP packets for:

- A device claiming to be the gateway.
- Repeated changes in IP-to-MAC mappings.
- Large numbers of ARP requests.
- Conflicting ARP replies.
- Evidence of ARP spoofing.

ARP findings should be compared with switch data and endpoint information before reaching a conclusion.

Packet Captures Are Sensitive

Packet captures may contain:

- Passwords.
- Session cookies.
- Authentication tokens.
- Internal hostnames.
- IP addresses.

-
- Personal data.
 - Confidential application content.

Even encrypted traffic can reveal metadata, such as who communicated, when they communicated, and how much data was transferred.

Captures should be collected only with authorization, stored securely, access-controlled, and deleted according to policy. When sharing a capture, analysts should filter or redact sensitive information. Wireshark guidance also recommends narrowing captures, recording context, correlating packet data with application logs, and treating PCAP files as sensitive evidence. [ldamoredev.github](https://github.com/ldamoredev)

10. IDS and IPS

What Is an IDS?

An **Intrusion Detection System**, or IDS, monitors traffic or system behavior and generates alerts when it identifies suspicious activity.

An IDS is generally passive. It observes the activity but does not automatically stop the connection.

For example, an IDS may alert:

Workstation 10.10.10.25 scanned 500 ports on internal servers.

The security team then investigates whether this was authorized testing, a network tool, a misconfiguration, or an attack.

What Is an IPS?

An **Intrusion Prevention System**, or IPS, is usually placed inline with network traffic. It can take action when it detects a threat.

An IPS may:

- Drop malicious packets.
- Block a source IP.
- Reset a TCP connection.
- Stop a known exploit pattern.
- Quarantine a device.
- Update a firewall rule.

The main difference is simple:

text

IDS: Detects and alerts

IPS: Detects and blocks

NIST describes intrusion detection and prevention as technologies that monitor events in systems and networks to identify possible security incidents and, in the case of prevention, attempt to stop them.[nist](#)

How IDS and IPS Detect Threats

Signature-based detection

Signature-based systems look for known patterns associated with attacks. They are effective against known malware, exploit attempts, and malicious traffic patterns.

The limitation is that they may not recognize new or modified attacks.

Anomaly-based detection

Anomaly-based systems compare activity against normal behavior. They may alert when a device suddenly creates many connections or transfers unusual amounts of data.

The limitation is that unusual does not always mean malicious. An anomaly system may generate false positives.

Behavior-based detection

Behavior-based systems examine activity over time and look for patterns such as reconnaissance followed by exploitation and lateral movement.

In practice, modern security systems often combine signatures, behavior, reputation, and machine-learning techniques.

IDS/IPS Placement

IDS and IPS sensors may be placed:

- At the internet boundary.
- Between security zones.
- Near data centers.
- In front of VPN gateways.
- Behind firewalls.
- In cloud networks.
- On individual hosts.

Placement affects visibility. A sensor outside the firewall may see scanning traffic that the firewall blocks. A sensor inside the network may see lateral movement after a device is compromised.

IDS/IPS Limitations

IDS and IPS systems cannot detect everything. They may struggle with:

- Encrypted traffic.
- Custom protocols.
- Highly modified attacks.
- Poorly tuned rules.
- High traffic volumes.

- Fragmented packets.
- Evasion techniques.
- Legitimate activity that resembles an attack.

An IPS configured too aggressively may block legitimate business traffic. Organizations often begin in detection mode, tune rules, and then enable blocking for well-understood threats.

11. Proxies and Web Proxies

What Is a Proxy?

A proxy acts as an intermediary between a client and a destination.

Without a proxy:

text

User device → Website

With a forward proxy:

text

User device → Forward proxy → Website

The proxy receives the request, applies policy, and sends the request to the destination.

Forward Proxy

A **forward proxy** is used by clients inside an organization. It can control and monitor outbound traffic.

Organizations use forward proxies to:

- Block malicious websites.
- Enforce browsing policies.
- Scan downloads.

- Record web activity.
- Restrict risky file types.
- Detect malware.
- Control access by user or department.
- Reduce access to prohibited content.

For example, a company may block access to known phishing websites or prevent downloads of dangerous executable files.

Reverse Proxy

A **reverse proxy** sits in front of servers.

text

Internet user → Reverse proxy → Web server

The user communicates with the reverse proxy rather than directly with the internal server.

A reverse proxy can provide:

- Load balancing.
- TLS termination.
- Caching.
- Authentication.
- Rate limiting.
- Web application protection.
- Hiding of internal server addresses.
- Request filtering.

Many public web applications use reverse proxies, content-delivery networks, and WAFs to handle internet traffic before it reaches application servers.

TLS Inspection

Because HTTPS encrypts web traffic, a proxy cannot normally see the full content. Some organizations use approved TLS inspection to decrypt, inspect, and re-encrypt traffic.

This can help detect malware and policy violations, but it must be designed carefully. TLS inspection may create:

- Privacy concerns.
- Performance overhead.
- Certificate-management complexity.
- Application compatibility problems.
- Problems with banking, healthcare, or certificate-pinned applications.

Organizations should define exceptions, protect inspection keys, inform users when appropriate, and ensure that inspection complies with legal and privacy requirements.

12. TLS and Encryption

What Is TLS?

TLS, or Transport Layer Security, protects data while it travels across a network. HTTPS uses TLS to secure web communication.

TLS helps provide:

- **Confidentiality:** Others cannot easily read the data.
- **Integrity:** Unauthorized changes can be detected.
- **Authentication:** The client can verify the server's identity.

When you visit an HTTPS website, your browser and the server negotiate secure communication. The server presents a certificate, and the browser checks whether the certificate is valid for that website and trusted by a recognized certificate authority.

What Certificates Do

A TLS certificate connects a public key with a domain name or organization identity. It helps the browser verify that it is communicating with the intended server.

A certificate may contain:

- The domain name.
- The server's public key.
- The certificate authority.
- The validity period.
- A digital signature.
- Alternative domain names.

The browser checks whether the certificate is expired, whether the hostname matches, whether the issuing authority is trusted, and whether the certificate has been revoked or otherwise invalidated.

HTTPS Does Not Mean a Website Is Safe

A website can use HTTPS and still be malicious. HTTPS means the connection is encrypted and associated with a valid certificate. It does not guarantee that the website owner is honest or that the content is safe.

For example, a phishing website can obtain a valid certificate. The connection may be encrypted, but the website can still steal credentials.

Users should check the domain name, use password managers, avoid suspicious links, and rely on security controls beyond the padlock symbol.

TLS Handshake

At a high level, a TLS connection involves:

1. The client and server communicate about supported security options.
2. The server provides its certificate.
3. The client validates the certificate.
4. The systems agree on session keys.

5. Encrypted communication begins.

Modern TLS versions should be used, while outdated protocols and weak cryptographic algorithms should be disabled.

TLS in Cybersecurity

Cybersecurity professionals should understand:

- Certificate authorities.
- Certificate expiration.
- Hostname validation.
- Certificate chains.
- Public and private keys.
- Cipher suites.
- TLS versions.
- Certificate revocation.
- Mutual TLS.
- Certificate pinning.
- TLS inspection.

Mutual TLS, or mTLS, requires both sides to present certificates. It is useful for service-to-service authentication, APIs, microservices, and zero-trust environments.

13. Authentication, Authorization, and Accounting

What Is AAA?

AAA stands for:

- **Authentication:** Who are you?
- **Authorization:** What are you allowed to do?
- **Accounting:** What did you do?

These three functions are essential for controlling access to routers, switches, firewalls, VPNs, cloud consoles, servers, and applications.

Authentication

Authentication verifies identity. It may use:

- Passwords.
- Security keys.
- One-time codes.
- Certificates.
- Biometrics.
- Smart cards.
- Mobile authenticator applications.
- Multi-factor authentication.

A password alone is often not enough for administrative or remote access. MFA adds another factor, making stolen passwords less useful to attackers.

Authorization

Authorization determines what an authenticated person or device is allowed to do.

For example:

`SOC analyst: View logs and investigate alerts`

`Network engineer: Modify firewall rules`

`Help-desk employee: Reset user passwords`

`Auditor: Read configuration but not change it`

Authorization should follow least privilege. Users should receive only the permissions required for their responsibilities.

Role-based access control makes this easier by assigning permissions to roles rather than individually configuring every user.

Accounting

Accounting records activity. It may include:

- Login time.
- Logout time.
- Source IP address.
- Device identity.
- Commands executed.
- Configuration changes.
- Files accessed.
- Authentication failures.
- VPN session duration.

Accounting is important during incident investigations. If a firewall rule changes unexpectedly, security teams need to know who changed it, when it changed, where the administrator connected from, and whether the change was approved.

RADIUS

RADIUS is commonly used for centralized authentication and network access. It can support VPNs, wireless networks, and other access systems.

A user may enter credentials into a VPN or Wi-Fi system. The access device sends the authentication request to the RADIUS server, which verifies the user and returns an accept or deny decision.

RADIUS helps organizations avoid creating separate local accounts on every device.

TACACS+

TACACS+ is commonly used for administrative access to network devices. It can separate authentication, authorization, and accounting more clearly than traditional approaches.

For example, a network administrator may be allowed to view configurations but not make changes unless they have a higher privilege level.

Centralized administrative access makes it easier to remove access when someone leaves the organization and to investigate configuration changes.

LDAP and Active Directory

LDAP is a protocol used to access directory information. **Active Directory** is a widely used directory service in Windows environments.

Directories can store users, groups, computers, and policies. Applications, VPNs, network devices, and security tools may use directory services to verify identities and determine group membership.

For example, a user in the “Network-Administrators” group may receive administrative access, while a user in the “Employees” group may receive ordinary application access.

AAA in a VPN

When a user connects to a VPN:

1. **Authentication** verifies the user with a password, certificate, or MFA.
2. **Authorization** determines which systems or applications the user may access.
3. **Accounting** records the login, source location, session time, and resources accessed.

A strong VPN design does not stop after authentication. It continues to evaluate what the user should be allowed to reach.

How These Work Together

Imagine that a remote employee connects to a company application.

1. The employee connects to the VPN from home.
2. AAA verifies the identity and MFA.

3. The VPN creates an encrypted tunnel.
4. The firewall assigns the user to an appropriate access zone.
5. ACLs allow access only to the required application.
6. Network monitoring records the connection.
7. An IDS or IPS analyzes traffic for suspicious activity.
8. TLS protects the application session.
9. A proxy or reverse proxy filters and routes the request.
10. Logs are sent to the SIEM for investigation if necessary.

This layered approach is stronger than relying on the VPN alone.

Final Understanding

A VPN protects the connection, but it does not automatically make the user or device safe.

Network monitoring provides visibility, but it must be connected to useful logs and investigation processes.

Wireshark shows packet-level details, but packet captures must be handled as sensitive information.

An IDS detects suspicious activity, while an IPS may block it.

A proxy controls communication between users and destinations.

TLS protects data in transit, but HTTPS does not prove that a website is trustworthy.

AAA verifies identity, controls permissions, and records activity.

Together, these technologies provide confidentiality, visibility, access control, detection, and accountability the major building blocks of modern network security.